

情報-情報セキュリティ

1. 本题考察的是第7章（网络与信息安全模块）中极其经典的攻击手法——**パスワードリスト攻撃 (Credential Stuffing / 密码撞库攻击)**。

核心考点解析：

- **パスワードリスト攻撃**：攻击者通过非法手段获取某一个网站（或服务）泄漏的用户凭证（包含利用者ID（用户名）与パスワード（密码）的清单列表），然后利用这批清单去尝试登录其他完全不同的Web网站（他のWebサイト）。其核心原理是利用了很多人在不同网站习惯使用相同账号密码的弱点。

为什么“どこかのWebサイトから流出した利用者IDとパスワードのリストを用いて、他のWebサイトに対してログインを試行する”是正确答案？

- **解析**：这完美契合了“密码撞库（Password List Attack）”的定义：利用从某处泄露的ID和密码列表（List），去“撞击（试探）”其他网站的登录大门。

为什么其他选项是错误项或干扰项？

- **选项1**（一般的な単語や人名からパスワードのリストを作成し...）：利用常见单词或人名组合来猜解密码，这属于 **辞書攻撃 (Dictionary Attack / 字典攻击)** 或 **ブルートフォース攻撃 (Brute Force / 暴力破解)**，而不是密码撞库。
- **选项2**（想定され得るパスワードとそのハッシュ値との対のリストを用いて...）：利用预先计算好的密码与哈希值对照表来反向破解，这属于 **レインボー攻撃 (Rainbow Table Attack / 彩虹表攻击)**。
- **选项4**（ピクチャパスワードの入力を録画してリスト化し...）：通过录制图形密码输入轨迹来盗用，这属于侧信道攻击或窥视手法，与密码撞库无关。



考试小秘籍

- “パスワードリスト攻撃考点速记” 口诀：
 - 看到题目中出现「流出した...リストを用いて」「他のWebサイトに対して」（利用泄漏的清单、去其他网站尝试登录）→ 闭眼锁定 **パスワードリスト攻撃**！关键词“流出”加“其他网站”就是撞库的铁证。

2. 本题考察的是第7章（信息安全与密码学模块）中关于**公開鍵暗号方式 (Public-Key Cryptography / 公开密钥密码体制)**的核心原理与经典算法。

- **核心考点解析**：

- **公開鍵暗号方式 (Public-Key Cryptography)**: 使用两个不同的密钥——**公開鍵 (Public Key)** 用于加密, **秘密鍵/復号鍵 (Private Key/Decryption Key)** 用于解密。其核心优势在于密钥分发简便 (不需要安全通道传递私钥)。
- **RSA 算法**: 最著名的公开密钥密码算法, 其数学安全基石建立在大整数的素因数分解的困难性 (素因数分解の困難さ) 之上。

为什么“RSAは、素因数分解の計算の困難さを利用した公開鍵暗号方式である。”是正确答案?

- **解析**: RSA 加密算法的安全性正是基于“要把一个大合数分解成两个质数的乘积极其困难”这一数学难题。这句话在密码学考点中属于绝对的标准表述。

考试小秘籍

- “密码学考点速记” 口诀:
 - 看到 **AES** → 瞬间反应它是 **共通鍵** (对称密码), 不是公开密钥。
 - 看到 **RSA** → 闭眼连线「**素因数分解**」(质因数分解困难), 这是考卷上出现频率最高的黄金搭档!

3. 本题考察的是第7章 (信息安全与密码学模块) 中关于**电子邮件安全标准与加密机制**的核心概念。

- **核心考点解析**:
 - **S/MIME (Secure/Multipurpose Internet Mail Extensions)**: 是一种用于对电子邮件进行**加密 (暗号化)** 和**数字签名 (デジタル署名)** 的安全标准协议。它利用公钥密码体制 (Public-Key Cryptography) 来确保电子邮件在传输过程中的机密性、完整性及发送方身份的真实性。

考试小秘籍

- “邮件安全考点速记” 口诀:
 - 看到题目问 **電子メールを暗号化 (电子邮件加密)** → 闭眼锁定 **S/MIME!** 首字母 S 代表 Secure (安全), 是邮件加密的绝对代名词。

4. 本题考察的是信息安全与身份认证 (Authentication) 中关于密码存储与验证机制 (パスワードのハッシュ値保存・比較) 的核心原理。

核心考点解析:

- **明文不落地原则**: 系统 (服务器) 绝不能以明文 (Plaintext) 形式保存用户的密码, 因为一旦数据库被黑客窃取, 所有用户的明文密码将直接泄露。
- **哈希加密与比对机制**: 系统会在用户注册时, 将用户的パスワード (密码) **通过ハッシュ関数 (哈希函数)** **单向转换为ハッシュ値 (哈希值)** 并保存到数据库中。在登录认证时, 系统会对用户实时输入的密码进行同样的哈希计算, 将得出的哈希值与数据库中预先存储的哈希值进行**比对 (比較)**, 从而判断密码是否正确。

考试小秘籍

○ “密码哈希认证考点速记” 口诀：

- 看到密码存储选项 → 记住：“存的是哈希，比的是哈希”。绝对不能存明文，也绝对不能拿用户ID去和密码哈希做文章！

5. 本题考察的是第7章（网络与信息安全模块）中关于局域网底层欺骗与中间人攻击的核心考点——**ARPスプーフィング攻撃 (ARP Spoofing / ARP欺骗攻击)**。

核心考点解析：

- **ARP协议 (Address Resolution Protocol)**：负责将网络层的 **IPアドレス (IP地址)** 转换为数据链路层的 **MACアドレス (MAC地址)**。
- **ARPスプーフィング攻撃 (ARP欺骗/投毒)**：攻击者通过发送伪造的ARP应答报文，把局域网内某个合法的IP地址强行绑定到攻击者自己的 **MACアドレス (MAC地址)** 上，从而制造出错误的对应关系。这样一来，原本发往该IP的数据包就会全部被劫持到攻击者的电脑里，常用于窃听或中间人攻击。

“伪造快递收件人身份证的比喻”：

- 在局域网这个大院子里，大家寄信只认门牌号 (**IP地址**) 和居民身份证号 (**MAC地址**)。
- 坏人张三偷偷跑去物业的登记表上乱改：把“小明的家 (IP)”对应的身份证号写成了张三自己的身份证号 (**MAC地址**)。结果大院里所有送给小明的信，全被快递员错送到张三家里去了！这种篡改“门牌号与身份证号对应关系”的恶劣行径，就是 **ARPスプーフィング (ARP欺骗)**。

 考试小秘籍

○ “网络攻击考点速记” 口诀：

- 看到题目同时出现「**IPアドレス**」和「**MACアドレス**」→ 别犹豫，闭眼锁定带有「**ARP**」字样的选项 (**ARPスプーフィング攻撃**)！它们是一对死绑定的黄金组合。

6. 本题考察的是第7章（信息安全与密码学模块）中关于侧信道攻击 (Side-Channel Attack / サイドチャンネル攻撃) 中极为特殊的物理侦测手段——**テンペスト攻撃 (TEMPEST Attack / 电磁泄露窃密攻击)**。

核心考点解析：

- **テンペスト (TEMPEST)**：是指通过截获和分析电子设备在工作时向空气中**无意辐射出的电磁波 (漏洩電磁波)**，来还原出屏幕显示内容或机密数据的一种物理安全攻击方式。它属于典型的旁路攻击 (Side-Channel Attack) 的一种。

TEMPEST攻击 就像是特工把一个超高灵敏度的收音机贴在保密室的墙外，靠接收电脑内部电路板辐射出来的**电磁波 (漏出的杂音)**，居然在隔壁把屏幕上的机密文件给“听”出来了！这种偷听电磁波的绝招，名字叫 TEMPEST。

“TEMPEST考点速记” 口诀：

- 看到题目出现 **テンペスト (TEMPEST)** → 脑子里立刻锁定三个字：“**电磁波**”。只要选项里看到「**電磁波を観測し解析する**」，闭眼选它绝对没错！

7. 本题考察的是第7章（信息安全与密码学模块）中关于**公開鍵暗号方式 (Public-Key Cryptography / 公开密钥密码体制)** 与 **共通鍵暗号方式 (Symmetric Key Cryptography)** 的核心特征、应用场景（如数字签名）的辨析。

核心考点解析：

- **デジタル署名 (Digital Signature / 数字签名)**：利用公开密钥密码体制实现的数字签名技术。其核心原理是：发送方用自己的**秘密鍵 (Private Key)** 对摘要进行加密形成签名，接收方用该发送方的**公開鍵 (Public Key)** 进行解密验证。这完美体现了公开密钥密码在身份认证和防篡改上的应用。

为什么“電子商取引などで使用されるデジタル署名には、公開鍵暗号の技術が使われている。”是正确答案？

- **解析**：数字签名（Digital Signature）本质上就是公开密钥密码体制（Public-Key Cryptography）的反向应用（私钥加密，公钥解密）。因此，这句话在技术原理上是绝对正确且符合考试规范的。

为什么其他选项是错误项或干扰项？

- 选项ア（公開鍵暗号を使用してデータを暗号化する通信では、暗号化するための鍵を、どのように安全に配送するか工夫する必要がある）：**错误**。公开密钥的巨大优势恰恰在于“公钥是公开的，不需要担心在网络上被窃听”，真正需要费心思安全配送的是对称密码（**共通鍵**）的密钥。
- 选项イ（データを暗号化して通信することによって、データの破壊や改ざんを防ぐことができる）：**错误**。加密（暗号化）解决的是机密性（Confidentiality / 防止偷看）**问题，而防止篡改和破坏需要靠数字签名（Digital Signature）或哈希校验（MAC/Hash）来保证完整性**。加密本身防不了改动。
- 选项工（不特定多数とのデータ通信においては、公開鍵暗号よりも共通鍵暗号が適している）：**错误**。如果与不特定多数人通信，共通鍵需要给每个人发一把不同的密钥，会导致密钥管理爆炸（呈几何级数增长）。因此，不特定多数通信（如互联网HTTPS购物）恰恰更依赖**公開鍵暗号**。

“数字签名与密码锁的比喻”：

- **数字签名（盖上专属红手印）**：就像你在合同上盖的私人印章。别人用你公开的放大镜（**公開鍵**）就能验明真伪，但只有你手里那枚刻章（**秘密鍵**）才能盖出来。这必须用到公开密钥技术！
- **加密防偷看 vs 防篡改**：锁上保险箱（**加密**）只是不让别人偷看里面的东西；如果别人半路把保险箱直接砸碎或换掉（**篡改**），锁是防不住的，必须靠“防伪标签（**数字签名**）”。

“密码学辨析考点速记” 口诀：

- 看到 **デジタル署名 (数字签名)** → 闭眼联想它和「**公開鍵暗号**」（公开密钥密码）是形影不离的亲兄弟！
- 看到 **暗号化 (加密)** → 记住它只管“不被偷看（机密性）”，管不了“有没有被偷偷修改（完整性）”。

8. 公開鍵暗号方式 (Public-Key Cryptography): 核心原理是“成对出现”的密钥——**公開鍵 (Public Key)** 和 **秘密鍵 (Private Key)**。

通信秘匿 (加密通信) 逻辑: 为了确保“只有B能看懂”，加密者 (A) 必须使用接收者 (B) 的**公开鍵**进行加密。因为 B 的秘密鍵只有 B 自己拥有，所以世界上只有 B 一个人能解开这把锁。

为什么正确答案是“**ウ (Bさんの公開鍵)**”？

- **解析:** 题目要求 A 把信息发给 B，并且要“保密”。
 - 如果用 A 的公钥加密，谁都能解（因为公钥是公开的），没有保密效果。
 - 如果用 B 的公钥加密，因为与之对应的 B 的秘密鍵只有 B 一个人有，所以只有 B 才能解密。这完美实现了“保密”。

“公共信箱比喻”：

- **B 的公开鍵 (Bさんの公開鍵)** = B 放在大门口的一个“投递口”。谁都可以把信塞进去，但只有 B 有钥匙能打开里面的抽屉。
- 如果你 (A) 想给 B 寄秘密，你必须把信塞进 B 的这个投递口。只要你塞进去了，就算路上有黑客拦截，由于他没有 B 的私家钥匙（**秘密鍵**），他永远也打不开这封信。
- **口诀:** “加密要找收信人，必须使用TA的公钥（公开鍵）！”

“公开密钥考点速记” 口诀：

- 看到题目问 “**为了保密 (秘密に) 把文章发给对方**” → 绝对是用 “**对方的公开鍵**” (相手の公開鍵)。
- 看到题目问 “**为了证明是我发的 (签名)**” → 绝对是用 “**自己的秘密鍵**” (自分の秘密鍵)。
- **加密锁与收信人绑定，签名与发信人绑定**，这就是公开密钥密码的全部逻辑！

在公开密钥密码体制中，为了实现上述的加密和签名，**双方必须预先建立信任关系并交换公开鍵**。

- **交换逻辑:** A 和 B 在通信前，必须把自己那把“任何人都可以拿走的锁（公开鍵）”放到一个“公共广场”或通过安全方式交给对方。
- **关键问题 (现实中的难点):** 如果 A 拿到的公钥是冒充者 C 给的，那 A 不就中招了吗？所以，现实中我们使用 **数字证书 (デジタル証明書/Digital Certificate)**。也就是由“第三方公证人 (CA, 认证机构)”来打包发送公钥，告诉 A：“这就是 B 的公钥，是真的，请放心拿去锁门。”

你问：“在发送具体文章之前，双方应该交换公开鍵吗？”

- **答案:** 必须交换，或者说必须能获取到对方的公开鍵。

○ 流程如下：

- i. **准备阶段**：A 生成自己的“公钥+私钥”，B 生成自己的“公钥+私钥”。
- ii. **获取阶段**：A 拿到 B 的公钥（存入 A 的地址簿），B 拿到 A 的公钥（存入 B 的地址簿）。
- iii. **执行阶段**：
 - **A 给 B 发密文**：A 从地址簿里取出 B 的公钥，把文件锁上，发给 B。
 - **B 解密**：B 拿出自己私有的私钥，打开锁。
 - 反之亦然，如果 B 要给 A 发秘密文件，就得去查 A 的公钥。

“PKI 考点防坑手册”：

- 考试时如果题目问“如何保证公钥不被篡改？”，答案永远是：「デジタル証明書」(数字证书) 以及「認証局 (CA)」。
- 记住：**公钥配送是第一步，是地基**。没有这个地基，后面的加密通信就是空中楼阁。

9. 本题考察的是第8章（信息安全与用户认证/防护模块）中关于Web防自动化攻击（Anti-Automation/Bot Detection）的核心技术——**CAPTCHA (Completely Automated Public Turing test to tell Computers and Humans Apart)**。

● 核心考点解析：

- **CAPTCHA 的本质**：这是一种“图灵测试”的变体。它的核心逻辑在于利用**计算机难以处理图像识别与模糊逻辑**的弱点，通过扭曲字符、添加噪点、背景混淆等手段，人为设置一个只有“人类大脑”能识别，而“计算机程序 (Bot)”难以识别的障碍，从而有效防止恶意自动脚本（如暴力注册、垃圾灌水、批量抢票）对网站的自动化滥用。👉就是平时的图片验证码验证用户不是机器是活人

10. 本题考察的是信息安全管理中最核心的“三要素 (CIA)”及其扩展特性中的「否認防止」(Non-repudiation / 不可否认性)。

○ 情報セキュリティの特性 (信息安全三要素及扩展)：

- **機密性 (Confidentiality)**：只有经过授权的人才能访问（对应选项：认知的用户才能使用）。
- **完全性 (Integrity)**：数据是准确、完整的，没有被非授权篡改。
- **可用性 (Availability)**：授权用户在需要时可以访问（对应选项：被允许的用户在要求时可以使用）。
- **否認防止 (Non-repudiation)**：指当某个行为发生后，行为的主体无法事后抵赖“这件事不是我干的”。也就是通过证据，证明该行为的发生与特定主体之间的对应关系。

为什么“ある利用者があるシステムを利用したという事実が証明可能である。”是正确答案？

- **解析**：「否認防止（不可否认性）」的核心逻辑在于“溯源”与“证据保留”。如果系统能证明“确实是某位用户操作了这个系统”，那么当发生安全事件或纠纷时，这位用户就无法否认自己的行为。这就是不可否认性的定义。

为什么其他选项是错误项？

- “認可された利用者が要求したときにアクセスが可能である。” → 这是 **可用性 (Availability)** 的定义。
- “認可された利用者に対してだけ、情報を使用させる又は開示する。” → 这是 **機密性 (Confidentiality)** 的定义。
- “利用者の行動と意図した結果とが一貫性をもつ。” → 这个选项描述比较模糊，通常不属于信息安全标准定义中的核心特性，更像是业务正确性或逻辑完整性的范畴。

“信息安全特性考点速记” 口诀：

- 看到 **否認防止** → 瞬间锁定 **「証明可能」**（能够证明）、**「追跡可能」**（可以追踪）、**「事後報告」**（事后不能赖账）。
- 这就是为了防止“做贼心虚的人”事后翻供，所以必须留下铁证！

11. 本题考察的是**共通鍵暗号方式 (Symmetric Key Cryptography / 对称密钥密码体制)**的核心机制与应用场景。

- 共通鍵暗号方式的本质：**加密和解密使用**同一把密钥**（共通鍵）。
- 对比核心：**它与公开密钥密码体制（公開鍵暗号方式）形成了鲜明对比。
 - 优点：**加解密速度非常快，非常适合处理大数据量的加密。
 - 缺点/痛点：**由于双方必须拥有同一把密钥，因此在与多人通信时，必须为每一对通信者（或每一个通信对象）分配不同的密钥，这会导致密钥管理规模呈指数级增长（N 个人通信就需要分配大量密钥）。

选项解析与详细说明

- 为什么“通信相手ごとに異なる共通鍵が必要である。”是正确答案？
 - 解析：**这是对称密钥最大的管理难题。如果你要和 100 个人分别进行秘密通信，你不能给每个人都发同一把钥匙（因为其中任何一人泄露了，所有人的秘密都保不住），你必须为每一个通信对象（通信相手）都准备一把独立的、不同的共通鍵。
- 为什么其他选项是错误项？
 - “暗号化以外に、デジタル署名にも利用される。” → 错误。数字签名（Digital Signature）必须使用公开密钥密码体制（非对称密码）。
 - “公開鍵暗号方式に比べて、復号速度は一般的に遅い。” → 错误。对称密钥算法（如 AES）的计算复杂度远低于非对称算法（如 RSA），所以它**非常快**，而不是慢。
 - “代表的な方式として、RSA方式がある。” → 错误。RSA 是**公开密钥密码**的代表，不是共通鍵的。

“共通鍵 vs 公開鍵 考点速记” 口诀：

- 看到 **共通鍵 (对称)** → 联想 **“快”**（处理速度快）和 **“烦”**（管理密钥烦，要一对一分配）。

- 看到 **公開鍵 (非对称)** → 联想 “慢” (算法复杂) 和 “签” (数字签名专用, RSA是代表)。
- 只要记住 “共通键通信相手多, 管理就头大”, 这道题就稳拿分!

12. **デジタル署名 (Digital Signature)** 的核心功能是: 「**発信元の認証 (身份认证)**」和「**改ざん検知 (完整性验证)**」。

机密性 (Confidentiality): 这是 **暗号化 (Encryption)** 的专属职责。

数字签名的逻辑: 数字签名保证的是 “这封信确实是谁发的, 且没被改动”, 但它**并不强制要求**信件内容是乱码 (不可见)。

题目明确说的是 “数字署名 (Digital Signature)”。数字签名的过程通常只是对邮件内容的 **哈希值 (Hash)** 进行加密。它**并不改变**邮件正文的原文状态。

如果只是加了数字签名而没有进行 “加密”, 那么这封邮件的内容依然是**明文 (Plaintext)**。任何中转的服务器或黑客截获后, 可以直接读取内容。所以, 数字签名无法防止内容被 “盗看”。

“数字签名考点口诀”:

- 看到 **数字签名 (デジタル署名)** → 记住两点: “认人 (c)” 和 “看有没有改 (d)”。
- **绝对不要选:** 任何带有 “不被偷看 (盗み見)” 或者 “没病毒 (ウイルス)” 的选项。那是 “加密” 和 “杀毒软件” 的活, 签名不干这个!

13. 本题考察的是信息安全中最具破坏力、应对难度最大的攻击手法——**ゼロデイ攻撃 (Zero-day Attack / 零日攻击)**。

◦ **核心考点解析:**

- “**Zero-day**” 的命名逻辑: 指厂商刚刚发布补丁, 或者甚至还没发现漏洞的存在, 攻击就已经发生了。因为漏洞被发现的当天即是漏洞利用的 “第0天” (Zero Day), 此时开发者根本没有时间 (Zero Day time) 来制作和发布安全补丁。
- **核心特征:** 利用漏洞的 “时间差”。在漏洞被广为人知、安全厂商来不及修复 (提供 Patch) 之前进行攻击, 因此具有极高的成功率和隐蔽性。

“零日攻击考点速记” 口诀:

- 看到 「**ゼロデイ**」 → 瞬间锁定关键词: 「**パッチ提供前**」 (补丁提供前)、「**脆弱性**」 (脆弱性/漏洞)、「**未対応**」 (尚未应对)。
- 这是一场和时间的赛跑, 只要厂商还没修好, 就是它的主场!

14. 本题考察的是第7章 (信息安全模块) 中关于**恶意软件 (Malware) 分类**的考点。重点辨析 **アドウェア (Adware / 广告软件)** 的定义及其核心行为模式。

◦ **核心考点解析:**

- **アドウェア (Adware):** 顾名思义, “Ad” 代表广告, “Ware” 代表软件。其核心目的是 “展示广告”。它通常在用户不知情的情况下安装, 或者捆绑在免费软件中, 强制在用户的桌面、浏览器或程序运行过程中弹出广告窗口, 从而通过流量和点击获取收益。虽然它通常不像病毒那样破坏数据, 但严重干扰用户使用。

为什么“PCの画面上に広告を表示させる。”是正确答案？

- **解析：**这是广告软件（Adware）最典型、最核心的特征。它的主要任务就是向用户终端推送广告，不管用户愿不愿意，广告都会在屏幕上“弹出来”。

为什么其他选项是错误项？

- “ネットワークで接続されたコンピュータ間を、自己複製しながら移動する。” → 这是 **ワーム (Worm / 蠕虫病毒)** 的典型行为，强调自动复制和传播。
- “ネットワークを介して、他人のPCを自由に操ったり、パスワードなど重要な情報を盗んだりする。” → 这是 **バックドア (Backdoor / 后门)** 或 **トロイの木馬 (Trojan / 木马)** 的典型功能，侧重于非法操作和信息窃取。
- “ワープロソフトや表計算ソフトのデータファイルに感染する。” → 这是 **マクロウイルス (Macro Virus)** 的特征，专门感染 Office 文档等数据文件。

“恶意软件考点速记” 口诀：

- 看到 **アドウェア (Adware)** → 瞬间想到：“**Ad = 广告**”。选项里只要有“**広告**” (广告) 二字，百分之百选它。
- 看到 **ワーム (Worm)** → 想到：“**虫子爬**” (自我复制/移动)。
- 看到 **トロイの木馬 (Trojan)** → 想到：“**伪装成好东西骗你装**” (看起来有用但其实带毒)。

15. 本题考察的是第7章（信息安全与PKI模块）中关于 **CRL (Certificate Revocation List / 证书吊销列表)** 的定义与运作机制。

◦ **CRL 的核心本质：**

- **什么是 CRL？**：当一个数字证书（即使还没到期）因为私钥泄露、持有人离职或信息变更等原因需要“提前作废”时，认证机构（CA）会将该证书列入一个黑名单，这个名单就叫 **CRL（失控列表）**。
- **核心逻辑**：只有在证书有效期内（本来应该有效），但因为特殊情况被提前取消（吊销）的证书，才会被列入 CRL。

为什么“認証局は、有効期限内のデジタル証明書をCRLに登録することがある。”是正确答案？

- **解析：**这是对 CRL 定义的最准确描述。虽然证书本身有有效期，但在有效期内，一旦发现私钥泄露等风险，必须将其提前“吊销（失效）”。因此，CRL 里记录的就是这些“依然在有效期内，但已被提前作废”的证书。

为什么其他选项是错误项？

- 选项ア (PKIの利用者は、...CRLを参照しなくてもよい): 错误。即使浏览器内置了 CA 的公钥，也**必须**查看 CRL 才能确认对方的证书是否被提前吊销了。如果不看 CRL，就会信任已经作废的证书，造成安全风险。
- 选项イ (発行したすべてのデジタル証明書の有効期限をCRLに登録する): 错误。CRL 记录的是“被吊销（失效）的”证书，而不是记录所有证书的有效期。

- 选项ウ (失効後1年間CRLに登録するよう義務付けられている): 错误。关于失效率的保存期限并没有这种“强制规定1年”的硬性规定, CA 具体的运维策略由其证书政策 (CP) 决定。

“CRL 考点速记” 口诀:

- 看到 **CRL** → 瞬间锁定关键词: 「失効 (吊销)」, 「有効期限内 (在有效期内)」。
- 只要选项里说 CRL 登记的是“所有证书”或者“不需要查看”, 直接排除! CRL 只记那些“还没过期就被赶出来的倒霉鬼”。

16. 这道题考查的是信息安全术语的核心定义。在 **JIS Q 27000 (信息安全管理系统——术语)** 中, 每一个安全特性都有其严谨的逻辑定义:

- **真正性 (Authenticity / 真正性)**: 指确认实体 (用户、设备、信息) 就是它所宣称的那一个, 即“身份真实、不被冒充”。
- **信頼性 (Reliability / 可信赖性)**: 指实体的行为与预期结果保持一致, 即“靠谱、稳定、始终如一”。

JIS Q 27000:2019(情報セキュリティマネジメントシステム—用語)における真正性及び信頼性に対する定義a~dの組みのうち, 適切なものはどれか。

〔定義〕

- a. 意図する行動と結果とが一貫しているという特性
- b. エンティティは, それが主張するとおりのものであるという特性
- c. 認可されたエンティティが要求したときに, アクセス及び使用が可能であるという特性
- d. 認可されていない個人, エンティティ又はプロセスに対して, 情報を使用させず, また, 開示しないという特性

平成 29 年春期 問 24

24 問目 / 選択中の問題 316 問

	真正性	信頼性
ア	a	c
イ	b	a
ウ	b	d
エ	d	a

ア

イ

ウ

エ

首先我们要先完成对定义 a~d 的“身份识别”:

- **a. 意图的行为与结果一致** → **信頼性 (Reliability)**。就像一个人承诺的事一定会做到, 结果和行为一致, 这就是“靠谱”。

- b. 实体就是它所主张的那一个 → **真正性 (Authenticity)**。即“名副其实”，确认身份真实。
- c. 授权实体请求时可以访问 → **可用性 (Availability)**。
- d. 不对未经授权者开示信息 → **機密性 (Confidentiality)**。

考试小秘籍

- “术语辨析考点速记” 口诀：
 - **真正性 (Authenticity)** → 找「主張」(主张/声称) + 「一致」(相符)。只要看到“说自己是 谁就是谁”，选它！
 - **信賴性 (Reliability)** → 找「意図」(意图) + 「一貫」(一贯/一致)。只要看到“做事始终如一，符合预期”，选它！
 - 千万不要把 **信賴性 (Reliability)** 和 **可用性 (Availability)** 搞混。一个是“行为靠谱”，一个是“随叫随到”。

17. 本题考察的是第7章（信息安全模块）中关于恶意软件隐蔽入侵与长期潜伏机制的核心概念——**バックドア (Backdoor / 后门)**。

- **核心考点解析：**
 - **バックドア (Backdoor)**：攻击者在首次非法入侵企业内部网络或服务器后，为了绕过常规的正规认证机制（如账号密码登录），秘密在系统内部植入的一条“秘密通道”。通过这个后门，攻击者日后可以随时自由出入、操控目标系统并窃取重要数据。
- **为什么“バックドア”是正确答案？**
 - **解析：**题目问的是“攻击者为了侵入企业内部网络或服务器而预先埋入的东西”（企業内ネットワークやサーバに侵入するために攻撃者が組み込むものはどれか。）。这完美契合了后门（Backdoor）的定义——它是攻击者留下的秘密出入口。

（为了侵入企业网络或服务器而組み込む/嵌入的东西） → 闭眼锁定 **バックドア (Backdoor)!**
“后门”就是留给坏人以后随时回来的秘密通道。

18. 本题考察的是第8章（Web应用安全漏洞模块）中最著名的漏洞之一——**クロスサイトスクリプティング (Cross-Site Scripting / XSS / 跨站脚本攻击)**。

- **核心考点解析：**
 - **XSS (跨站脚本攻击)**：攻击者通过在 Web 应用程序的输入框、评论区等地方（**入力フィールド**），恶意插入包含脚本语言（如 **JavaScript 代码**）的数据。当其他用户浏览该网页时，这些恶意脚本会在用户的浏览器中被执行，从而窃取用户的 Cookie、Session 或冒充用户进行非法操作。

为什么“Webアプリケーションに用意された入力フィールドに、悪意のあるJavaScriptコードを含んだデータを入力する。”是正确答案？

- **解析：**这精准命中了 XSS 攻击的核心手法——通过输入字段（Input Field）注入恶意的 JavaScript 代码。网站如果没有对输入做充分的转义或过滤，就会把这段代码当作正常网页内容显示并执行。

“XSS 考点速记” 口诀：

- 看到 **クロスサイトスクリプティング** → 瞬间锁定双胞胎关键词：「**入力フィールド**」（输入字段）+ 「**JavaScript**」。
- 只要在考卷里同时看到这两个词，闭眼选它绝对拿分！

19. 本题考察的是第7章（网络与信息安全模块）中极具破坏力的网络欺骗手段——**DNSキャッシュポイズニング (DNS Cache Poisoning / DNS缓存投毒)**

核心考点解析：

- **DNS 缓存投毒的本质：**攻击者向 DNS 服务器（或客户端）注入伪造的、虚假的域名解析记录（域名与 IP 的对应关系）。当用户访问某个正规网址时，由于 DNS 服务器被“投毒”，误信了虚假记录，从而把用户不知不觉地引导到黑客精心伪装的 **钓鱼网站（偽装されたWebサーバ）** 上。

为什么“**PCが参照するDNSサーバに誤ったドメイン管理情報を注入して、偽装されたWebサーバにPCの利用者を誘導する。**” 是正确答案？

- **解析：**这句话完美涵盖了 DNS 缓存投毒的两个核心动作：**1. 注入错误的域名管理信息（Poisoning/投毒）；2. 将用户引导至伪造的 Web 服务器（钓鱼/劫持）。**这正是 DNS 缓存投毒的标准定义。

“DNS 缓存投毒考点速记” 口诀：

- 看到 **キャッシュポイズニング (Cache Poisoning)** → 闭眼锁定两个关键词：「**誤った情報**」（错误信息/投毒）+ 「**誘導**」（把用户引到假网站）。只要这两样凑齐，绝对是它！

20. 本题考察的是第7章（信息安全与认证模块）中关于**跨域身份认证与单点登录（SSO）**标准的核心理论——**SAML (Security Assertion Markup Language)**。

核心考点解析：

- **SAML (Security Assertion Markup Language)：**是由标准化组织 OASIS 制定的一种基于 XML 的开放标准。它专门用于在不同的 Web 应用程序（如企业内部系统与外部云服务之间）**安全地交换用户的认证（Authentication）、属性（Attributes）及授权（Authorization）信息**，是实现企业级单点登录（SSO）的关键技术。

为什么“**SAML**” 是正确答案？

- **解析：**题目中明确指出了三个核心线索：**1. 标准化组织 OASIS；2. Webサイト間（不同的Web网站/系统之间）；3. 安全交换认证、属性及授权信息（認証、属性及び認可の情報）。**这完全对位了 SAML 协议的官方标准定义。

“SAML 考点速记” 口诀：

- 看到题目同时出现 **OASIS + Webサイト間**（不同网站间）+ **認証・認可の情報交換**（认证与授权交换）→ 别犹豫，闭眼锁定 **SAML**！这是考卷里雷打不动的黄金绑定关系。
21. 本题考察的是信息安全与用户认证模块中的经典身份验证方法——**乱数表方式 (密码矩阵/坐标密码认证)**。

◦ **核心考点解析：**

- **乱数表认证 (Matrix Card Authentication)：**系统发给每个用户一张印满随机数字的表格（乱数表，且**每个用户的表格内容各不相同**）。每次登录时，系统会随机抽取几个坐标（如 B1, C2），用户需要填入对应坐标上的数字作为本次登录的密码。
- **核心特性：**因为每次系统抽取的坐标都是随机变化的，所以哪怕黑客在旁边偷听或截获了你这次输入的密码（比如 24644131），由于下次坐标会变，这个密码也**完全废了**，从而有效防止了重放攻击（Replay Attack）。

为什么“**ウ (盗聴したパスワード利用による, なりすましの防止に有効である。)**”是正确答案？

- **解析：**因为每次输入的密码（数字组合）根据随机抽取的坐标**实时变化**，即使黑客在网络上或旁边盗听（盗聴）了你这次输入的密码，由于下一次登录时系统要求的坐标完全不同，这个旧密码就成了废纸一张。因此，它对防止利用被窃听密码进行的冒充攻击（なりすまし）非常有效。

“乱数表考点速记” 口诀：

- 看到题目出现 **乱数表** → 记住两个绝对：
 - i. 它属于「**所持認証**」（拥有物品认证，因为要带表）。
 - ii. 它的最大优点是「**盗聴に強い / 防止なりすまし**」（不怕偷听，因为密码每次都变，能防冒充）。
- 只要选项里看到「**盗聴**」和「**なりすまし防止**」凑在一起，闭眼选它！

22. 本题考察的是密码学中各类密钥的**机密性要求（谁必须保密，谁可以公开）**。

◦ **核心考点解析：**

- **a. 共通鍵 (Symmetric Key)：**在 **共通鍵暗号方式 (对称密钥密码体制)** 中，加密和解密使用的是**同一把钥匙**。因为通信双方靠这把唯一的钥匙来解密和加密文件，一旦这把共通键落入第三方（黑客）手中，黑客就能轻而易举地解密所有传输的数据。因此，**共通键必须作为最高机密严格管理，绝不能泄露**。
- **b. 公開鍵 (Public Key)：**顾名思义是“公开”的，供任何人拿去加密或验签，因此不需要对第三方保密。
- **c. 秘密鍵 (Private Key)：**属于非对称密码体系中只有自己拥有的私钥，必须严格保密。

看到 **公開鍵** → **唯一一个可以大声公开的钥匙！**

看到 **共通鍵** 和 **秘密鍵** → 只要不是“公开”二字的钥匙，统统要当成传家宝一样严格保密！别被“共通”两个字迷惑以为它是公开的。

23. 本题考察的是日本密码学与网络安全管理体系中一个极具代表性的官方组织——CRYPTREC (Cryptography Research and Evaluation Committees / 密码技术研究与评估委员会)。

◦ 核心考点解析：

- CRYPTREC 的本质：由日本数字庁、総務省、経済産業省等政府部门共同运营的项目/委员会。
- 核心职责：其最核心的任务是对电子政府（政府机关）所使用的各种暗号（密码）技术进行安全性和实现性能的客观评估、调查与监控，并定期公开发布和维护「電子政府推奨暗号リスト」（电子政府推荐密码列表）。

为什么“電子政府での利用を推奨する暗号技術の安全性を評価, 監視する”是正确答案？

- 解析：这精准命中了 CRYPTREC 的官方定义：评估和监视电子政府推荐使用的加密技术的安全性。它就像是日本政府专门设立的“密码安全质检局”。

“CRYPTREC 考点速记” 口诀：

- 看到 CRYPTREC → 闭眼锁定带有「電子政府」和「暗号技術の安全性」（密码技术安全性）的选项！
- 它是密码界的“权威裁判”，只负责查密码安不安全，不搞出口审批，也不抓黑客攻击。

24. 本题考察的是第7章（信息安全与认证模块）中极具代表性的企业身份认证架构——シングルサインオン (Single Sign-On / SSO / 单点登录)。

◦ 核心考点解析：

- シングルサインオン (SSO)：用户只需要在系统（或门户）进行一次性登录（一度の認証），就可以凭这一个凭证访问所有被授权的多个不同的服务器、系统或应用程序（複数のサーバやアプリケーション），而不需要在每一个系统里重复输入账号密码。

为什么“シングルサインオン”是正确答案？

- 解析：题目中明确描述了“一度の認証で, 許可されている複数のサーバやアプリケーションなどを利用できる仕組み”（通过一次认证，就能使用多个被授权的服务器或应用的机制）。这正是单点登录（SSO）的标准定义。

为什么其他选项是错误项或干扰项？

- スマートカード (Smart Card)：智能卡。这是一种物理硬件载体（卡片），主要用于存储证书或进行硬件级别的身份认证，而不是“一次登录访问多个系统”的机制。
- バイオメトリクス認証 (Biometrics Authentication)：生物特征认证（如指纹、人脸识别），属于认证的手段，而不是多系统互通的架构。
- ワンタイムパスワード (One-Time Password / OTP)：一次性密码。这是一种每次登录都在动态变化的密码技术，用于提高单次登录的安全性，同样与“多系统联动”无关。

“单点登录考点速记” 口诀：

- 看到「一度の認証」（一次认证）+「複数のサーバやアプリ」（多个服务器或应用）→ 绝对是 **シングルサインオン (SSO)**！这两个条件同时出现时，闭眼选它，绝无例外。

25. 本题考察的是第7章（信息安全与恶意软件模块）中声名显赫的勒索软件——**WannaCryptor (WannaCry / 永恒之蓝勒索病毒)**。

WannaCry 的核心特征：它是一种利用了 Windows 系统中 **SMBv1 协议漏洞（著名的 EternalBlue / 永恒之蓝漏洞）** 进行网络自传播的勒索软件（Ransomware）。感染后会强行加密用户电脑内的大量数据文件（如文档、照片等），随后锁死屏幕并弹出勒索窗口，要求支付比特币（Bitcoin）等虚拟货币来换取解密密钥。

为什么“SMBv1の脆弱性を悪用するなどして感染し、PC内のデータを暗号化してデータの復号のための金銭を要求したり、他のPCに感染を拡大したりする。”是正确答案？

- **解析：**这句话完美命中了 WannaCry 的三大灵魂特征：1. 利用 **SMBv1** 漏洞进行局域网内疯狂自动传播；2. **暗号化**（把文件加锁加密）；3. 勒索赎金（要求金钱来解密/复号）。

“WannaCry 考点速记” 口诀：

- 看到 **WannaCryptor / WannaCry** → 闭眼寻找两个黄金关键词：「**SMBv1**」和「**金銭要求 / 暗号化**」。
- 只要看到它利用网络漏洞自动传播并要赎金，直接选它，绝不会错！

26. 本题考察的是第7章（信息安全与攻击防御模块）中网络攻击生命周期里最基础的侦察阶段——**ポートスキャン (Port Scanning / 端口扫描)**。

ポートスキャン (端口扫描)：在攻击者正式发动攻击之前，通常会进行**事前調査 (偵察段階)**。他们通过向目标主机的各个端口发送探测数据包，来检查哪些端口是开着的、上面运行着什么服务（如Web、FTP、SSH等）。这就像小偷在动手前，先去挨个转悠、敲敲各家各户的门窗，看看哪家没上锁、哪家有漏洞可钻。

为什么“事前調査の段階で、攻撃できそうなサービスがあるかどうかを調査する”是正确答案？

- **解析：**端口扫描的唯一目的就是“在动手前的侦察阶段，摸清敌情”。看看目标系统上到底开启了哪些能被利用的服务（比如脆弱的旧版组件），属于典型的**事前調査**。

为什么其他选项是错误项或干扰项？

- 选项 2（権限取得の段階で、権限を奪取できそうなアカウントがあるかどうかを調査する。）：寻找可以夺取权限的账号，这属于**凭据猜解 / 暴力破解 / 社会工程学**，而不是扫描端口。
- 选项 3（不正実行の段階で、攻撃者にとって有益な利用者情報があるかどうかを調査する。）：寻找有用的用户信息，这属于攻击得手后的**数据窃取与搜索阶段**。
- 选项 4（後処理の段階で、システムログに攻撃の痕跡が残っていないかどうかを調査する。）：检查系统日志有没有留下痕迹并进行擦除，这属于攻击完成后的消除痕迹（Anti-Forensics / 善后）阶段。

“端口扫描考点速记” 口诀：

- 看到 **ポートスキャン (Port Scan)** → 脑子里瞬间蹦出三个字：“**踩点 / 侦察 / 事前調査**”！
- 它是攻击的第一步，永远在正式动手之前。选项里只要看到「**事前調査**」，闭眼选它！

27. 本题考察的是哈希函数（Hash Function）的几个关键数学特性：

- **输入输出关系**：哈希函数具有“定长输出”的特性。无论输入多大的文件，SHA-256 永远输出 **256 bit (即 64 位 16 进制数)** 的哈希值。
- **冲突 (Collision)**：指两个不同的输入（文件 A 和 文件 B）产生相同的哈希值。虽然在理论上哈希函数追求“抗碰撞性”，但如果题目明确指出“文件 A 和文件 B 计算出的哈希值**完全相同**”，这在密码学中是一个极其罕见且危险的现象，但在逻辑推导题目中，它意味着这两个文件的哈希指纹没有区别。
- **关键误区**：哈希值相同，**并不代表**原文件内容一定相同（虽然概率极低，但存在冲突），但在考试逻辑中，我们要从“哈希结果”出发进行判断。

为什么“**ファイルAの内容とファイルBの内容は同じである。**”（或在选项语境下，这是最符合哈希结果同构逻辑的判断）？

- **解析**：在大多数考试题目中，如果两个文件的哈希值完全一致，除非题目暗示存在碰撞攻击，否则通常结论是：这两个文件被视为具有相同特征的副本，即内容相同。这是哈希函数“唯一性/确定性”逻辑的逆向应用。

“哈希考点速记” 口诀：

- 看到「**哈希值一致**」 → 记住结论：“**内容相同**”。
- 看到「**哈希长度/桁数**」 → 记住：“**永远固定**”（无论文件是 1KB 还是 1GB，SHA-256 永远是 64 位 16 进制数，即 256 bit）。
- 千万别被“文件变大，哈希值也变长”这种选项骗了，这是哈希函数最基本的常识陷阱！

28. 本题考察的是第8章（Web应用安全模块）中，一种无需用户交互即可发动攻击的技术——**ドライブバイダウンロード (Drive-by Download / 路过下载攻击)**。

- **核心考点解析**：
 - **Drive-by Download (路过下载)**：字面意思是“开车路过就顺便下载”。其核心逻辑是：当用户仅通过浏览器浏览（閲覧）某个被黑客篡改或放置了恶意代码的网站时，无需用户点击下载按钮，也无需用户手动点击运行，恶意程序就会通过浏览器的漏洞（如浏览器插件漏洞、脚本执行漏洞等）**自动**下载并安装到用户的 PC 上。

为什么“**Webサイトを閲覧したとき、利用者が気付かないうちに、利用者の意図にかかわらず、利用者のPCに不正プログラムが転送される。**” 是正确答案？

- **解析**：这句描述精准捕捉了“Drive-by”的精髓：1. **閲覧したとき**（仅浏览时）；2. **気付かないうちに**（在不知不觉中）；3. **意図にかかわらず**（不经用户允许）；4. **自動転送・実行**（程序自动下载并感染）。

“路过下载考点速记” 口诀：

- 看到 **ドライブバイダウンロード** → 瞬间想到：“**閲覧するだけ**”（仅浏览）。
- 只要选项里出现“**无需下载点击**”、“**用户不知情**”、“**浏览网页时**”这三个要素，它就是“路过下载”没跑了！

29. 本题考查的是 **S/MIME** 环境下，**发送署名邮件（デジタル署名）** 的最小必要条件。

- **核心逻辑**：数字签名验证的核心是“收件人（B）使用发件人（A）的公钥进行验证”。因此，只要 B 能够获取到 A 的公钥（并通过证书证实其真实性），B 就可以完成验证工作。
- **证书需求结论**：如果是单向的“署名邮件发送”，**核心在于发件人（A）必须证明自己的身份**。因此，A 必须持有证书；而 B 在此过程中仅充当验证者，并不强制要求其预先持有证书（虽然在双向加密通信中 B 也需要证书，但就该题的“署名邮件”场景而言，B 是不需要的）。

为什么“Aさんはあらかじめ、自身の公開鍵証明書の発行を受けておく必要があるが、Bさんはその必要はない。”是正确答案？

- **解析**：
 - i. **A 的义务**：A 需要通过证书（公開鍵証明書）来证明自己的身份，并向 B 提供自己的公钥（公開鍵）。
 - ii. **B 的自由**：B 收到邮件后，使用 A 的公钥进行签名验证（署名の検証）。**B 验证 A 的签名，并不需要 B 自己先申请一个证书。**

为什么“Aさん、Bさんともに…”（之前的错误项）是错误的？

- **解析**：之前的逻辑过度扩展到了“双向加密通信”的范畴。题目明确限定在“署名付きメールを送信”（发送署名邮件）这一动作，因此 B 没有必要为了“接收邮件”而去预先申请证书，这是过度配置（Over-provisioning）。
- **“S/MIME 签名考点速记”口诀**：
 - 看到「署名付きメール」（署名邮件）→ 记住：“**发件人（A）必须有证，收件人（B）随意**”。
 - 如果题目改成「暗号化メール」（加密邮件），那才是“**双方都要有证**”！千万别把“签名”和“加密”混为一谈，这是出题人最喜欢埋雷的地方！

30. 哈希函数（Hash Function）在信息安全中扮演着“数字指纹”的角色。要理解它，必须掌握其四大核心“基因”：

- **决定性 (決定性)**：同样的文件，无论算多少次，指纹（哈希值）必须完全一致。
- **雪崩效应 (雪崩効果)**：文件哪怕只改动一个标点符号，生成的指纹也会发生天翻地覆的变化，根本看不出原先的痕迹。
- **单向性/原像计算困难性 (一方向性)**：这是它最“高冷”的地方，给你指纹，你绝对无法反推出原始文件是什么。
- **抗碰撞性 (衝突耐性)**：两个不同的文件，很难算出同一个指纹。

为什么“メッセージダイジェストからメッセージを復元することは困難である。”是正确答案？

- **解析：**这精准对应了哈希函数的“**一方向性 (One-wayness)**”。哈希过程是一个不可逆的“单行道”转换。正是因为这种“计算上不可能从结果推导出原始输入”的特性，才保证了数据的安全性。

“哈希函数考点速记” 口诀：

- 看到 **哈希函数** → 瞬间想到：“**不可逆、定长、抗冲突**”。
- 考试时只要看到选项中有“还原/复原”、“不同内容相同指纹”、“指纹长度随输入改变”等字眼，**一律秒杀（判错）**！因为它违背了哈希函数最根本的数学逻辑。

31. 本题考查的是信息安全中消息认证码（MAC）及消息摘要（Message Digest / Hash）在密码学应用中的核心目的。

什么是消息摘要（Message Digest）与消息认证码？ 在密码学中，通过单向散列函数将任意长度的明文消息压缩成固定长度的摘要（Message Digest），并以此来生成消息认证码。

它的核心作用是什么？ 它的终极使命不是对消息进行加密（因为它不是用来保密的），而是用来**验证和确保消息在传输或存储过程中没有被任何人恶意篡改（メッセージが改ざんされていないことを確認する）**。

为什么“メッセージが改ざんされていないことを確認する。”是正确答案？

- **深度拆解：**这精准命中了消息认证码与摘要的核心功能。无论中间数据怎么缩减成摘要，其最本质的出发点都是为了完整性校验——只要内容动了一个标点符号，摘要就会面目全非，从而让接收方一眼就能看出“消息被改ざん（篡改）了”。

为什么其他选项是错误项？

- 选项 **イ (確認する)**：摘要不负责确认加密方式，这是协议协商的事。
- 选项 **ウ (確認する)**：虽然字面上有“确认概要”，但考试的专业术语考点是“完整性与防篡改”，而不是单纯的“看概要”。
- 选项 **エ (メッセージの秘匿性を確保する)**：这是暗号化（加密）做的事情。消息摘要/认证码（MAC）本身是公开传输校验值的，不提供机密性（即它防篡改，但不防偷看）

“消息摘要考点速记” 口诀：

- 看到 **メッセージ認証符号** 或 **メッセージダイジェスト** → 脑子里瞬间锁定黄金词：“**改ざん**”（篡改 / 完整性）。

32. 本题考查的是加密算法标准中的硬性规定——**AES (Advanced Encryption Standard / 高级加密标准)**。

◦ **核心考点解析：**

- **AES 的本质：**由美国 NIST（国家标准与技术研究院）制定的对称密码算法，旨在取代早期的 DES。
- **密钥长度的硬性规定：**AES 并不是随意指定密钥长度的，NIST 明确规定了该算法支持的三种标准密钥长度：**128 bit、192 bit 和 256 bit**。除了这三种选择，不支持其他任意长度。

“AES 密钥长度考点速记” 口诀：

- 看到 **AES + 鍵長** → 瞬间脑内闪过：“一二八，一九二，二五六”。
- 这是 AES 唯一允许的三个数字，见到选项里有这三个数就直接锁定！看到“任意”或“加减 32”直接排除！
- データベースで管理されるデータの暗号化に用いることができかつ，暗号化と復号とで同じ鍵を使用する暗号化方式。

33. 本题考察的是信息安全管理体系统（ISMS）中涉及的舞弊风险预防理论——不正のトライアングル (Fraud Triangle)。

不正のトライアングル：由美国犯罪学家 Cressey 提出。理论认为，当一个人同时具备以下三个要素时，实施违规或欺诈行为（不正）的概率会极大增加：

- a. **機会 (Opportunity)**：客观上存在可乘之机（如管理漏洞）。
- b. **動機・圧力 (Motivation / Pressure)**：主观上有必须要做的原因（如个人债务、业绩压力）。
- c. **正当化 (Rationalization)**：心理上能找借口宽慰自己（如“公司反正不在乎这点钱”）。

“舞弊三角考点速记” 口诀：

- 看到「不正のトライアングル」→ 记住“**机动正**”（机会、动机、正当化）。
- 只要选项里不是这三个词，全部排除！如果题目问“如何防范舞弊？”，答案永远是：“消除其中的任何一个要素”。

34. 本题考查的是 PKI（公开密钥基础设施）体系中，专门负责“验证证书是否作废”的职能机构——VA (Validation Authority / 验证机构)。

VA (Validation Authority)：在 PKI 环境下，为了减轻认证局（CA）的压力，专门设置的一个服务节点。它的职责非常单一且明确：当用户或系统想要确认某个数字证书是否在有效期内被吊销时，向 VA 发起查询，VA 根据 CRL（证书吊销列表）或 OCSP 响应，直接回答“该证书当前的状态（是否有效）”。

为什么“デジタル証明書の失効状態についての問合せに応答する。”是正确答案？

- 解析**：VA 的全名就是“验证机构”，其核心业务就是“验证”。它通过提供证书的有效性状态（特别是是否已“失効/吊销”），来回应外界的查询请求。

“PKI 机构考点速记” 口诀：

- 看到 **VA** → 锁定“**失効状態 (失效状态)**”和“**応答 (响应查询)**”。
- 凡是看到“签发”、“签名”字眼的选项，直接排除 CA；凡是看到“本人确认”字眼的，排除 RA。VA 就是那个负责“查漏补缺、回答状态”的守门员！

35. 本题考查的是排列组合 (Permutation/Combination) 在密码强度分析中的基础应用。

- 核心考点解析**：
 - 密码组合的总数 = (可选择的字符数) ^ (密码位数)。

- **计算公式：**当密码长度 n 固定时，总组合数 $N = (\text{字符集大小})^n$ 。
- 本题计算的是：(新组合数) $\div$ (旧组合数)，即倍数关系。

计算步骤拆解：

a. 旧方案 (0~9 的数字)：

- 字符集大小 = 10 (即 0, 1, 2, 3, 4, 5, 6, 7, 8, 9)。
- 4位密码组合数 = $10^4 = 10,000$ 。

b. 新方案 (0~9 数字 + a~f 英小文字 6 文字)：

- 字符集大小 = $10 + 6 = 16$ 。
- 4位密码组合数 = $16^4 = 65,536$ 。

c. 倍数计算：

- 倍数 = $16^4 / 10^4$
- 利用幂运算性质： $(16/10)^4 = 1.6^4$
- 计算 $1.6 \times 1.6 \times 1.6 \times 1.6$ ：
- $1.6 \times 1.6 = 2.56$
- $2.56 \times 2.56 \approx 6.5536$

结论：约为 **6.6 倍**。

“密码强度计算口诀”：

- 看到“倍数”，先求**单字符集扩大了多少倍**（本题是 $16/10 = 1.6$ ）。
- 然后直接对其进行“密码位数”次方（ 1.6^4 ）。
- 千万不要被字数迷惑去算总数，直接用“底数倍数”的次方算，又快又准！

36. 本题考查的是信息安全模块中的**恶意软件传播机制**，特别是利用操作系统历史漏洞的典型攻击手法——**Autorun.inf 滥用**。

Autorun.inf 的机制：这是 Windows 系统为了实现“插入移动设备后自动弹出菜单或安装驱动”而设置的配置文件。

攻击逻辑：攻击者将恶意程序（USB 蠕虫/Worm/ワーム）放入 USB 存储设备，并编写一个恶意的 `Autorun.inf` 文件，该文件明确指向该恶意程序的运行路径。当受害者的电脑插入此 USB 时，系统会自动读取并根据 `Autorun.inf` 的指示**自动执行**该恶意程序，从而实现病毒传播。

为什么“特定ワームのファイル名を登録したAutorun.infファイルをUSBメモリ内に生成する。”是正确答案？

- **解析：**这是 Autorun.inf 蠕虫的“施工图”。它通过在 `Autorun.inf` 中注册（设置）指向蠕虫本体程序的名称和执行指令，从而达成插入 USB 后自动触发感染的目的。

“Autorun 漏洞考点速记” 口诀：

- 看到 **Autorun.inf** → 锁定两个关键词：「**ファイル名**」（文件名）+ 「**登録**」（登记/注册）。
- 只要选项里说它是“把病毒埋进配置文件”这种说法，通通判错！它是通过**登记/注册文件路径**来骗电脑去自动执行病毒的，这个逻辑一定要分清！

37. 本题考查的是 **デジタル署名 (数字签名)** 的全套标准工作流程。

- 核心考点解析：**
 - 数字签名的核心由两步组成：
 - 签名生成（发件人）：**发件人先用**哈希函数**对邮件内容压缩成摘要（メッセージダイジェスト），然后用发件人自己的**秘密鍵**（秘密鍵）对这个摘要进行加密，从而生成数字签名，并与原文一起发送。
 - 签名验证（收件人）：**收件人用发件人的**公開鍵**（公開鍵）解密签名得到摘要，并对比自己算出来的摘要，从而确认是不是发件人亲笔且未被篡改。

 **排查表：数字签名流程中的“键”与“动作”对照**

动作阶段	谁来做？	核心工具/键	正确的逻辑	选项工错在哪里？
生成签名	発信者 (发件人)	秘密鍵 (私钥) + ハッシュ (哈希)	消息 → 哈希摘要 → 秘密鍵加密	错误地对“秘密鍵”哈希
验证签名	受信者 (收件人)	公開鍵 (公钥) + ハッシュ (哈希)	签名 → 公開鍵解密 = 自己算的摘要	颠倒了主客体与加

正确的逻辑（选项イ）：发件人用自己的私密印章（秘密鍵）把信的摘要封好；收件人用发件人的公开防伪镜（公開鍵）打开信，再自己拿放大镜（哈希函数）核对信的内容。两边一对，一模一样，证明没被偷换！

“数字签名考点速记” 口诀：

- 看到数字签名，记住铁律：“**自己私钥（秘密鍵）加密签名，别人公钥（公開鍵）解密验证**”！
- 选项里只要出现“**用秘密鍵做哈希**”或者“**用公開鍵加密**”，直接闭眼判错！因为私钥用来签名（加密），公钥用来验签（解密），这个方向在考卷里永远不变！

38. 本题考查的是 **共通鍵暗号方式 (对称密钥密码体制)** 在多人相互通信时所需密钥数量的计算逻辑。

- 核心考点解析：**
 - 在对称密码体制中，由于通信双方必须使用**同一把钥匙**，因此每两个想要安全通信的人之间都需要独立分配一把私密密钥。
 - 如果有 n 个人两两之间都要进行相互通信，这就变成了一个数学上的**组合问题**（从 n 个人中选出 2 个人组成一个通信对）。

- 计算公式: $\frac{n \times (n - 1)}{2}$

“对称密钥数量考点速记” 口诀:

- 看到「共通鍵暗号方式」+「何個の鍵が必要か」(需要多少个密钥) → 脑子里瞬间锁定公式: $n(n - 1)/2$!
- 考试时不管给你 5 个人、8 个人还是 10 个人, 把数字带进去一除, 秒出答案, 绝不耽误时间!

39. 本题考查的是信息安全模块中 PKI (公钥基础设施) 与 SSL/TLS 协议的核心支撑技术——デジタル証明書 (数字证书)。

◦ 核心考点解析:

- 数字证书的作用: 在 SSL/TLS 协议的握手阶段, 服务器会向客户端出示自己的数字证书。客户端通过它来验证通信对方的身份 (认证), 并获取服务器的公开鍵 (公開鍵) 用于后续安全会话中的密钥交换 (鍵交換)。

为什么 “デジタル証明書は, SSL/TLS プロトコルにおいて通信データの暗号化のための鍵交換や通信相手の認証に利用されている。” 是正确答案?

- 解析: 这完美概括了数字证书在现实网络安全中的两大杀手锏功能: 1. 身份认证 (認証) (证明你是你); 2. 密钥交换 (鍵交換) (带出公钥, 帮大家安全商量出对称加密的钥匙)。

为什么其他选项是错误项?

- 选项 1 (S/MIME や TLS で利用するデジタル証明書の規格は, ITU-T X.4400 で規定されている。): 错误。数字证书的标准国际规范是 ITU-T X.509 (不是 X.4400)。
- 选项 3 (認証局が発行するデジタル証明書は, 申請者の秘密鍵に対して認証局がデジタル署名したものである。): 错误。认证局 (CA) 是对申请者的公开鍵 (公開鍵) 进行数字签名, 而不是对 “秘密鍵” (秘密鍵是申请者自己藏着的, CA 压根看不见也摸不着)。
- 选项 4 (ルート認証局は, 下位層の認証局の公開鍵にルート証明書の公開鍵でデジタル署名したデジタル証明書を発行する。): 错误。根证书 (Root CA) 对下位 CA 签名时, 必须使用根 CA 的秘密鍵 (秘密鍵) 来签名, 而不是用根证书的 “公开鍵” 去签名 (公钥只能用来验证, 不能用来签名)。

“数字证书考点速记” 口诀:

- 看到 デジタル証明書 的功能题 → 锁定: 「認証」 (认证) + 「鍵交換」 (密钥交换)。
- 如果选项里出现 “对秘密鍵签名” 或者 “用公钥签名” → 立刻打叉! 记住: CA 永远是用自己的秘密鍵去给别人的公开鍵盖章!

40. 本题考查的是密码学中最基础的分类——公開鍵暗号方式 (Public-Key Cryptography / 非对称密钥密码体制) 的核心特征与代表算法。

◦ 核心考点解析:

- 非对称/公开密钥加密的特征: 它使用两把不同的钥匙——公开鍵 (公開鍵) 用于加密, 秘密鍵 (秘密鍵) 用于解密。

- **主流代表算法**：最经典的公开密钥密码算法包括 **RSA**（基于大整数质因数分解难题）和 **橢圓曲線暗号 (ECC / 椭圆曲线密码)**。

为什么“RSAや橢(だ)圓曲線暗号などの暗号方式がある。”是正确答案？

- **解析**：RSA 和椭圆曲线密码（ECC）正是公开密钥密码方式（非对称加密）在现实中最著名、考试中最常出现的两大代表性算法。这句话在定义和归类上完全正确。

为什么其他选项是错误项？

- **选项 1 (DESやAESなどの暗号方式がある。)**：错误。DES 和 AES 属于 **共通鍵暗号方式 (对称密钥密码体制)**，它们用的是同一把钥匙，而不是公开密钥。
- **选项 2 (暗号化鍵と復号鍵が同一である。)**：错误。这是“对称密码”的特征；而公开密钥密码的加密键和解密键是**不一样的**（一把公开、一把私密）。
- **选项 4 (共通鍵の配送が必要である。)**：错误。公开密钥加密的巨大优势就是“不需要在网络上安全配送共通密钥”，从而解决了密钥配送问题。需要安全配送密钥的是对称密码体制。

“公开密钥考点速记” 口诀：

- 看到 **公開鍵暗号方式** → 脑子里瞬间闪过两个字：“**RSA**” 和 “**橢圓曲線**”。
- 只要在考卷里看到 **AES/DES** → 绝对是共通键（对称）！只要看到 **RSA/ECC** → 绝对是公开键（非对称）！这个对应关系在考试里是送分题，千万别搞混！

41. 本题考查的是现代密码学中为了解决“安全性”与“计算速度”矛盾而设计的核心架构——**ハイブリッド暗号方式 (Hybrid Encryption / 混合加密方式)**。

○ **核心考点解析**：

- **为什么需要混合？** 对称密码（如 AES）加密速度极快，但“密钥配送”不安全；公开密钥密码（如 RSA）解决了密钥配送和身份认证问题，但加解密计算速度极慢、非常消耗 CPU。
- **混合加密的运作逻辑**：用公开密钥密码方式来安全地传递临时生成的“**共通鍵 (对称密钥)**”，随后使用这个**共通鍵对实际的大量正文数据进行对称加密传输**。它完美融合了二者的优点：既有公开密钥的安全，又有对称密钥的高效。

为什么“公開鍵暗号方式と共通鍵暗号方式を組み合わせることによって鍵管理コストと処理性能の両立を図る。”是正确答案？

- **解析**：这精准命中了混合加密的本质——将**公开密钥密码方式**与**共通鍵密码方式**结合（組み合わせる），从而兼顾了安全性（密钥安全管理）与处理性能（高效传输大数据）。

“混合加密考点速记” 口诀：

- 看到 **ハイブリッド暗号方式**（混合加密） → 脑子里瞬间锁定两个词：“**公開鍵**” + “**共通鍵**”。
- 考试选项里只要看到“把这两种结合起来（組み合わせる）”，别犹豫，直接选它！这就是送分题！

42. 本题考查的是第8章（Web应用安全漏洞模块）中非常经典的一种路径越权访问漏洞——**ディレクトリトラバーサル (Directory Traversal / 路径遍历 / 目录遍历攻击)**。

- **目录遍历攻击的本质：**Web 应用程序在处理用户请求的文件名或路径时，如果缺乏充分的过滤和校验（例如没有过滤 `../` 等相对路径跳转符），攻击者就可以通过输入特殊的路径名（如 `../../etc/passwd`），强行跳出 Web 服务器原本限定的根目录，去访问并不正当地浏览（不正に閲覧する）服务器上本不该公开的系统内部敏感文件。

为什么“**攻撃者が、パス名を使ってファイルを指定し、管理者の意図していないファイルを不正に閲覧する。**” 是正确答案？

- **解析：**这句话完美击中了目录遍历（Directory Traversal）的字面含义与攻击后果：通过操控路径名（パス名）指定文件，从而非法越权查阅（不正に閲覧する）本应保密的系统文件。

 排查表：常见 Web 漏洞与攻击行为特征对照表

攻击手法 (日语原件)	核心攻击载体 / 动作	考试中的高频关键词
ディレクトリトラバーサル	通过路径名越权读取内部文件	パス名、ファイルを指定、不正に閲覧
SQLインジェクション	注入数据库查询命令	データベース、SQL文
クロスサイトスクリプティング (XSS)	网页注入并执行 JavaScript 脚本	スクリプト、エスケープ処理の欠陥
セッションハイジャック	窃取并冒用会话 ID	セッションID、なりすまし

“目录遍历考点速记” 口诀：

- 看到 **ディレクトリトラバーサル (Directory Traversal)** → 脑子里瞬间锁定两个词：「パス名」（路径名）+ 「不正に閲覧」（非法浏览文件）。

43. 本题考查的是信息安全模块中现代身份认证的高级策略——**リスクベース認証 (Risk-Based Authentication / 基于风险的认证)**。

リスクベース認証 (Risk-Based Authentication)：这是一种“动态、按需触发”的智能认证机制。系统会持续分析用户的访问环境（如**IP地址、使用的终端、地理位置、访问时间**等）。如果发现这次登录环境和以往完全一致（低风险），用户只需要正常登录；但如果系统检测到“**いつもと異なる**”（与平时不同）的异常环境（比如平时在日本上网，突然从海外高风险IP登录），系统就会判定为高风险，并**自动追加额外的验证步骤**（如短信验证码、邮箱二次确认等）。

为什么“**利用者のIPアドレスなどの環境を分析し、いつもと異なるネットワークからのアクセスに対して追加の認証を行う。**” 是正确答案？

- **解析：**这句话精准命中了风险认证的核心定义：1. 分析环境（IP地址等）；2. 识别异常（与平时不同的网络/环境）；3. 动态触发追加认证。这就是风险基准认证的标准运作逻辑。

“风险认证考点速记” 口诀：

- 看到 **リスクベース認証 (Risk-Based)** → 瞬间锁定两个救命关键词：「**いつもと異なる**」（与平时不同）+ 「**追加の認証**」（追加认证）。
- 只要在考卷里看到“根据环境异常与否决定要不要加考一道题”，不用怀疑，闭眼选它！

44. 本题考查的是网络安全模块中极具破坏力的网络欺骗手段——**DNSキャッシュポイズニング (DNS Cache Poisoning / DNS缓存投毒)**。

DNS 缓存投毒的本质：攻击者向客户端所参照的 **DNS 服务器**（或者客户端本身）注入伪造的、虚假的域名管理信息（域名与 IP 地址的对应关系）。当用户想要访问某个正规网址时，由于 DNS 服务器被“投毒”，误信了虚假记录，从而把用户不知不觉地引导到黑客精心伪装的 **钓鱼网站（偽装されたサーバ）** 上。

为什么“**PCが参照するDNSサーバに偽のドメイン情報を注入して,利用者を偽装されたサーバに誘導する。**” 是正确答案？

- **解析：**这句话完美契合了 DNS 缓存投毒的两个核心动作：1. **注入虚假域名信息**（偽のドメイン情報を注入して/投毒）；2. **将用户引流到假网站**（偽装されたサーバに誘導する/诱导）。这就是 DNS 缓存投毒的标准定义。

“**DNS缓存投毒考点速记**” 口诀：

- 看到 **キャッシュポイズニング (Cache Poisoning)** → 闭眼锁定两个黄金关键词：「**偽のドメイン情報**」（虚假域名信息/投毒）+ 「**誘導**」（引诱到假服务器）。

45. 本题考查的是信息安全与恶意软件模块中一类隐蔽性极高的后门工具——**ルートキット (Rootkit / 根工具包)**。

Rootkit 的本质：当攻击者通过不正当手段（如漏洞利用）成功侵入目标系统后，为了能够长期潜伏且不被管理员发现，他们会安装一组被称为 **Rootkit** 的工具集合。其核心功能是“隐蔽（隠蔽）”——通过篡改或劫持操作系统底层的文件、进程、网络连接或日志管理API，把自己的恶意进程、木马文件和后门账号全部隐藏起来，让管理员的常规检查失效。

为什么“**不正に侵入してOSなどに不正に組み込んだものを隠ぺいする機能をまとめたツール**” 是正确答案？

- **解析：**这句话精准命中了 Rootkit 的核心灵魂——“隐蔽（隠蔽）”。Rootkit 的字面意思虽然包含“Root”（最高权限），但它在考卷里的核心特征永远是“把非法入侵后留下的痕迹和恶意程序藏起来”。

“**Rootkit 考点速记**” 口诀：

- 看到 **ルートキット (Rootkit)** → 脑子里瞬间锁定一个绝对关键词：「**隠蔽**」（隐蔽/藏匿）。
- 只要在考卷里看到“把入侵的脏东西藏起来、不让管理员发现”，闭眼选它，绝对拿分！

46. 本题考查的是信息安全与身份认证模块中的核心认证机制——**チャレンジ・レスポンス認証 (Challenge-Response Authentication / 质询-响应认证)**。

- **核心考点解析：**

- **什么是挑战-响应认证？** 这种机制为了防止密码在网络中被直接窃听（重放攻击），由验证方（Y）发送一个随机生成的“挑战字符串（チャレンジ）”给被验证方（X）；X 结合双方事先约定好的规则（如密码或密钥）对这个随机字符串进行运算，生成一个“响应（レスポンス）”回传给 Y；Y 验证这个响应是否正确。
- **本题的验证方向是谁在认证谁？**
 1. Y（服务器/验证方）向 X（客户端）抛出一个随机数（Challenge）。
 2. X 必须用自己掌握的秘密（规则）回答出正确的响应（Response）。
 3. 在这个过程中，只有 X 能够证明自己知道这个秘密，从而向 Y 证明了 X 的身份。因此，这是 Y 验证 X 的身份，即 **“Y が X を認証する”**。

为什么“Y が X を認証する。”是正确答案？

- **解析：**谁发起挑战、谁检查答案，谁就是“认证者”。在本题中，Y 出了题（Challenge），X 交了答卷（Response），Y 负责批改判卷（确认 Response 是否正确）。因此，**Y 是考官（认证者），X 是考生（被认证者）**。所以结论是：Y 对 X 进行认证。
- **“挑战-响应考点速记”口诀：**
 - 看到 **チャレンジ (Challenge) を送信** → 谁发起的挑战，谁就是**考官（认证方）**！
 - 本题中 Y 发送挑战 → 必然是 **Y 认证 X**！这个对应关系在考卷里永远像磁铁一样牢固，看到直接秒选！

47. 本题考查的是信息安全与威胁情报模块中用于监测恶意软件活动的核心技术——**ダークネット (Darknet / 暗空间/黑洞网)**。

什么是 IT 领域的ダークネット (Darknet) ？ 在信息安全语境下，它不是指那些违法交易的暗网，而是指**互联网上那些已经被分配了 IP 地址，但实际上并没有连接任何真实的、正常的主机或服务器的“未使用 IP 地址空间”**。

它的用途是什么？ 因为这些 IP 根本没有正常业务，所以所有发往这些 IP 的流量（如扫描、蠕虫病毒探测、攻击试探）100% 都是非法的恶意流量或垃圾流量。安全人员在这些空间部署“观测传感器（Sensor）”，就能像在无人区设卡一样，清清爽爽地捕获并分析全网最新的病毒活动和攻击倾向。

为什么“インターネット上で到達可能, かつ, 未使用のIPアドレス空間”是正确答案？

- **解析：**这精准命中了 Darknet 的技术定义：虽然在互联网路由上能够到达（可达），但实际上是**未被正常使用的 IP 地址空间（未使用IPアドレス空間）**。正是因为“无人使用”，所以任何发到这里流量都可以直接判定为恶意探测或病毒扩散。

“Darknet 考点速记”口诀：

- 看到 **ダークネット (Darknet)** → 脑子里瞬间锁定两个黄金词：**「未使用」**（未使用）+ **「IP アドレス空間」**（IP 地址空间）。
- 只要在考卷里看到“有地址但没人用、专门用来抓病毒探测”的描述，闭眼选它，稳拿分数！

48. 本题考查的是 Web 应用安全模块中极具破坏力的注入攻击——**OSコマンドインジェクション (OS Command Injection / 操作系统命令注入)**。

OS命令注入的本质：当 Web 应用程序内部需要调用操作系统底层命令（例如在 Perl 中使用 `system` 函数，或在 PHP 中使用 `exec` 函数）来处理某些业务时，如果对用户输入的数据缺乏严格的过滤和校验，攻击者就可以在输入框中精心构造特殊的控制字符（如 `;` 或 `|`），从而欺骗后台系统**执行攻击者额外输入的任意操作系统 shell 脚本或可执行文件**。

为什么“OSコマンドインジェクション”是正确答案？

- **解析：**题目中明确指出了“利用 Perl 的 `system` 函数或 PHP 的 `exec` 函数调用外部程序，并不正当地执行 shell 脚本”。这正是 **OSコマンドインジェクション** 的教科书级定义和触发场景。

为什么其他选项是错误项？

- **HTTPヘッダーインジェクション (HTTP头部注入)：**这涉及篡改 HTTP 响应头（如进行会话固定或跨站脚本攻击），与操作系统的 shell 命令无关。
- **クロスサイトリクエストフォージェリ (CSRF / 跨站请求伪造)：**利用受害者在已登录状态下的浏览器权限，强制其发送非预期的恶意请求，不涉及后端调用系统命令。
- **セッションハイジャック (会话劫持)：**通过窃取 Session ID 冒充合法用户，与后台执行外部程序无关。

“OS命令注入考点速记” 口诀：

- 看到 `system` 或 `exec` 函数 → 闭眼锁定：**「OSコマンドインジェクション」**！
- 只要在考卷里看到程序调用了操作系统的外部函数、执行了 shell 脚本，不用犹豫，直接选它，稳稳拿分！

49. 本题考查的是信息安全模块中针对**登录密码的三种经典攻击手段（字典攻击、嗅探、暴力破解）与对应的防御对策**之间的正确连线匹配。

辞書攻撃 (Dictionary Attack / 字典攻击)：攻击者使用预先整理好的常用密码字典（如常见英文单词、生日等）进行批量尝试。**对策：**必须设置复杂的、随机的值（ランダムな値）或强密码，让字典无法命中。

スニффイング (Sniffing / 嗅探)：攻击者通过在网络中监听（窃听）未加密的通信，直接截获明文传输的账号密码。**对策：**绝对不能以明文发送密码（パスワードを平文で送信しない），必须使用 SSL/TLS 等加密传输。

ブルートフォース攻撃 (Brute-force Attack / 暴力破解/穷举攻击)：攻击者通过计算机的高速运算，把所有可能的字符组合全部尝试一遍。**对策：**针对登录试行次数设置门槛（ログインの試行回数に制限を設ける），例如连续输错 3 次就锁定账号，从而彻底打断其穷举。

“密码攻击防线考点速记” 口诀：

- 看到 **スニффイング (嗅探)** → 闭眼连线：**「平文で送信しない」**（不发明文）。
- 看到 **ブルートフォース (暴力破解)** → 闭眼连线：**「試行回数に制限」**（限制次数）。

- 剩下的 **辞書攻撃** → 对应：「**ランダムな値**」（随机值）。

50. 本题考查的是信息安全事件管理（Incident Management）中，如何将不同的网络安全异常现象准确归类到标准事件类型（Scan、Abuse、Forged、Infection/Intrusion、DoS、Other）中的分类逻辑。

Scan (扫描与不审访问)：指探测、扫描、端口探测及其他可疑的试探性访问。

Abuse (不正中继)：指恶意利用服务器功能进行垃圾邮件转发、代理中继等滥用行为。

Forged (伪造)：指伪造邮件发送头（Sender Header）等欺骗行为。

Intrusion (入侵)：指攻击者实际攻破系统、成功进入并留下痕迹的行为。

DoS (服务拒绝攻击)：指导致系统资源耗尽、服务中断或遭遇网络拥堵（ふくそう）阻碍正常运行的攻击。

逐一分析三个インシデント（事件）的归类：

- a. **インシデント 1（事件1）**：“ワームの攻撃が試みられた形跡があるが、侵入されていない。”（有蠕虫攻击的尝试痕迹，但没有被成功入侵）。
 - 分析：既然只是“尝试（试探）”且未成功，属于典型的扫描、探测或未遂试探，对应分类中的 **Scan**。
- b. **インシデント 2（事件2）**：“ネットワークの輻輳(ふくそう)による妨害を受けた。”（遭受了因网络拥堵带来的业务妨害）。
 - 分析：流量堵塞、服务受阻，完美对应服务拒绝攻击或网络拥堵妨害，对应分类中的 **DoS**。
- c. **インシデント 3（事件3）**：“DoS 用の踏み台プログラムがシステムに設置されていた。”（系统内被安装了用于发起 DoS 攻击的跳板程序）。
 - 分析：黑客已经把程序装进系统里了，说明系统**已经被成功攻破并植入**，属于系统被入侵（Intrusion）或被滥用。结合题干给出的六大分类定义：“踏み台に利用した不正中継”属于 Abuse，而系统内部被安放木马则对应实际侵入，但在本题的选项匹配中：对应 **Intrusion**（系统入侵后留下后门/跳板）。

“事件分类考点速记” 口诀：

- 看到 “**試みがられた**”（只是尝试、未成功） → 选 **Scan**。
- 看到 “**輻輳**”（网络拥堵/拥塞） → 选 **DoS**。
- 看到 “**プログラムが設置されていた**”（被安装了恶意程序/踏板） → 选 **Intrusion**（入侵）。

51. 本题考查的是恶意软件分类中近年来危害极大、特征极其鲜明的勒索软件——**ランサムウェア (Ransomware)**。

什么是ランサムウェア（勒索软件）？ 它的名字由 “Ransom（赎金）” + “Software（软件）” 组合而成。其核心破坏手段是：入侵电脑后，利用强加密算法将用户电脑中的重要文件（文

档、照片等)全部**加密(暗号化)**锁死,让用户无法打开;随后弹出勒索信,宣称必须支付金钱**(赎金)**才肯交出解密密码**(復号)**。

勒索软件考点速记” 口诀:

- 看到 **ランサムウェア (Ransomware)** → 脑子里瞬间锁定两个词:「**暗号化**」(加密)+「**金銭要求**」(索要金钱)。

52. 本题考查的是拒绝服务攻击 (DoS / Denial of Service) 中利用网络层底层协议缺陷进行流量轰炸的经典手段——**ICMP Flood 攻撃 (ICMP 泛洪攻击)**。

ICMP (Internet Control Message Protocol): 互联网控制报文协议,平时用于网络连通性测试(比如最常见的 **ping** 命令)。

ICMP Flood 的本质: 攻击者利用 **ping** 命令向目标服务器发送海量的 ICMP 请求包 (Echo Request), 通过消耗目标服务器的网络带宽或系统资源, 导致网络链路发生**过载(過負荷)**, 从而彻底瘫痪正常的访问请求。

为什么“**pingコマンドを用いて大量の要求パケットを発信することによって, 攻撃対象のサーバに至るまでの回線を過負荷にしてアクセスを妨害する。**” 是正确答案?

- **解析:** 这句话完美命中了 ICMP Flood 的两大核心特征: 1. **使用 ping 命令 / ICMP 报文** (ping コマンドを用いて大量の要求パケットを発信); 2. **导致网络回线过载瘫痪** (回線を過負荷にしてアクセスを妨害する)。这就是 ICMP 泛洪的教科书级定义。

“ICMP Flood 考点速记” 口诀:

- 看到 **ICMP Flood** → 脑子里瞬间锁定两个黄金词:「**pingコマンド**」(ping命令)+「**回線を過負荷**」(回线过载)。
- 只要在考卷里看到用 ping 发送海量包把网络带宽撑爆的描述, 别犹豫, 闭眼选它!

53. 本题考查的是密码学中两大核心密码体制——**共通鍵暗号方式 (对称密钥密码)** 与 **公開鍵暗号方式 (公开密钥/非对称密钥密码)** 的核心性能、安全依据以及应用场景的区别。

共通鍵暗号方式 (对称加密): 加解密使用同一把钥匙, 计算速度极快, 非常适合用于对大量数据(大量的数据)进行高效的加密处理。

公開鍵暗号方式 (非对称加密): 使用公钥和私钥两把钥匙, 虽然解决了密钥配送和身份认证问题, 但其底层数学运算极其复杂, **加解密计算速度极慢**, 不适合直接用来加密海量数据。

为什么“**大量のデータを取り扱う場合には, 公開鍵暗号方式よりも共通鍵暗号方式が適している。**” (对大量数据进行短时间加密时, 对称密码比公钥密码更合适) 是正确答案?

- **深度拆解:** 这精准命中了对称密码与非对称密码在性能上的根本分工。因为公钥密码 (如 RSA) 涉及巨大数字的乘方取模等复杂运算, 计算开销极高; 而对称密码 (如 AES) 算法精简、速度飞快。因此, 在实际网络传输中 (如 HTTPS/TLS 的混合加密), 我们永远是用公钥密码安全地传一个小密钥, 然后用**对称密码 (共通鍵暗号方式)** 去加密海量的大量数据。

为什么其他选项是错误项?

- 选项 ア (两者的安全依据都是大合数的质因数分解困难): 错误。大合数质因数分解困难仅仅是 **RSA（公钥密码）** 的安全根基；对称密码（如 AES）的安全性依赖于复杂的“混乱与扩散”（S-Box 替换与置换），两者的数学原理完全不同。
- 选项 イ (公钥密码原则上每次会话用不同钥匙，对称密码反复使用同一把钥匙): 错误。恰恰相反！在现代安全协议（如 TLS）中，为了防止长期使用一把对称密钥导致泄露，共通键（对称密钥）反而是每个 Session（会话）动态生成临时钥匙（Session Key）的；而公钥密码体系中的服务器数字证书和公钥往往是长期固定不变的。
- 选项 ウ (公钥密码规范化，对称密码通常由厂商独立实现): 错误。AES、DES 等主流对称密码恰恰是由美国 NIST 等机构进行国际标准化的，并不是厂商闭门造车的独自实现

“密码性能考点速记” 口诀：

- 看到「**大量的データ**」（大量数据）→ 脑子里瞬间锁定：「**共通鍵暗号方式**」！
- 考试选项里只要出现“公钥加密大数据”或者“公钥速度比对称快”的鬼话，直接判错！公钥负责安全交钥匙，对称负责高速运数据，这个分工在考试里是雷打不动的送分题！

54. 本题考查的是恶意软件分类中专门用来窃取用户输入的监控型木马——**キーロガー (Keylogger / 键盘记录器)**。

什么是キーロガー (Keylogger)？ 其名称由“Key（按键）”+“Logger（记录器）”组成。它的核心功能是：潜伏在用户的电脑或移动设备中，暗中**记录用户在键盘上敲下的每一个按键（キー操作を記録する）**。

它的主要危害是什么？ 攻击者通过分析这些被默默记录下来的键盘敲击日志，能够轻而易举地获取用户在登录网银、邮箱或社交平台时输入的**密码（パスワード）**、账号及信用卡号等高度机密信息。

“键盘记录器考点速记” 口诀：

- 看到 **キーロガー (Keylogger)** → 脑子里瞬间锁定两个词：「**キー操作**」（键盘操作）+「**パスワード収集**」（收集密码）。

55. 本题考查的是计算机犯罪与舞弊手段中非常经典的一种微量窃取手法——**サラミ法 (Salami Slicing Method / 萨拉米切片法)**。

什么是サラミ法（萨拉米法）？ 它的名字来源于将香肠（Salami）切成极薄的薄片。在计算机犯罪中，攻击者（通常是内部人员或黑客）利用计算机在处理海量数据、尤其是财务或账目时存在的“小数四舍五入”或“余数”机制，**在每次交易中悄悄刮走微不足道的一点点资产（如分厘之差）**。由于单次金额极小，完全不会惊动用户或表面账目（不正行為が表面化しない程度に），但由于基数庞大，积少成多，最终能聚沙成塔窃取巨额资产。

为什么其他选项是错误项？

- 选项 ア (回線の一部に秘密にアクセスして他人のパスワードやIDを盗み出し...): 这描述的是**盗号或窃密攻击**，与微量切片无关。

- 选项 イ (ネットワークを介して送受信されている音声やデータを不正に傍受する): 这描述的是 **スニффイング (Sniffing / 嗅探)**，侧重于网络监听。
- 选项 エ (プログラム実行後のコンピュータ内部...残っている情報をひそかに探索): 这描述的是 **残留数据挖掘/数据残留利用 (Data Remanence 滥用)**，不是萨拉米法。

“萨拉米法考点速记” 口诀：

- 看到 **サラミ法 (Salami Slicing)** → 脑子里瞬间锁定两个黄金词：**「少しずつ」** (一点点) + **「表面化しない」** (不被发现)。
- 只要在考卷里看到“每次悄悄偷一点点、总量巨大、不被察觉”，闭眼选它，稳稳拿下分数！

56. 本题考查的是“**不特定の利用者（无数的、不确定的广大网民/客户）**”向“**网站运营者**”发送**机密电子邮件**时，如何利用公开密钥密码方式（公开键暗号方式）来确保机密性。

为什么“**サイト運営者はサイト内のSSLで保護されたWebページにサイト運営者の公開鍵を公開し, 利用者は電子メールで送信するデータをその公開鍵で暗号化する。**”（网站运营者在受SSL保护的网页上公开自己的“公开键”，利用人用这个公开键加密发送的数据）是正确答案？

- 深度拆解您的疑问（为什么不是共通键？）：
 - 您刚才敏锐地察觉到“这是1对多的关系，应该找共通键吗？”。在日常的“双向私密聊天（比如 TLS/HTTPS 会话）”中，确实会为了传输效率，先用公钥安全交换一个临时“共通键”，再用共通键传大数据。
 - **但是！请注意审题：**这道题问的是“**不特定の利用者（不特定的大众网民）**”**如何给**“网站运营者”发加密邮件。
 - 大众网民和网站运营者之间**在此之前没有任何预先共享的秘密**！网民不可能在发邮件前先和网站运营者商量好一把共通键。
 - 怎么办？最简单、最标准的做法就是：网站运营者把自己的**公开键（公開鍵）**挂在官网上。**任何一个陌生网民（不特定利用者）**只要打开网页，拿走这个公钥，把信加密后发给运营者。这样运营者就能用自己的私钥打开。这就是经典的“**公钥加密，私钥解密**”的**单向机密信箱模型**！

“银行大厅门口的意见箱/投币口的比喻”：

- 银行（网站运营者）每天要接待成千上万个互不相识的陌生顾客（**不特定の利用者**）。
- 银行不可能给每个顾客发一把专属的小钥匙（共通键太难管理了）。
- 聪明的银行怎么做？他们在正门口挂了一个巨大且公开的“投币口（公开键）”。
- 任何一个陌生顾客，都可以把写有秘密的信件从这个公开的投币口塞进去（**用公开键加密**）。信一旦塞进去就掉进保险柜里，谁也拿不出来。最后只有拥有银行终极保险柜钥匙（**秘密键**）的行长才能打开。
- 所以，面对成千上万的陌生人发信，永远是“公布收件人的公开键，让大家加密塞进来”！

“不特定利用者发信考点速记” 口诀：

- 看到「**不特定の利用者**」（不特定的大众网民）→ 脑子里瞬间锁定：**绝对不能用共通键**（因为没法提前分发钥匙）！
- 必须用：「**運営者の公開鍵で暗号化**」（用运营者的公钥加密，像投意见箱一样）！牢记这个场景，考试绝对不丢分！

57. 本题考查的是网络安全与拒绝服务攻击（DoS / DDoS）中一种经典的放大与反射攻击——**Smurf 攻撃 (Smurf 攻击)**。

什么是 Smurf 攻击？ 攻击者向某个网络（或路由器）的广播地址（Broadcast Address）发送伪造了源 IP 地址（将其伪装成受害者的 IP）的 **ICMP 请求包（Ping 请求）**。

它的放大效应是如何实现的？ 当广播地址收到这个请求后，该网络下的所有主机都会误以为受害者在向它们发起 Ping，于是**所有主机同时向受害者发送大量的 ICMP 响应包（ICMPの応答パケット）**。这瞬间把流量放大了数十倍甚至数百倍，导致受害者的网络带宽被海量的 ICMP 响应彻底压垮。

“Smurf 攻击考点速记” 口诀：

- 看到 **Smurf 攻撃** → 脑子里瞬间锁定两个黄金词：「**ICMP**」+「**応答パケット**」（响应包）。
- 只要在考卷里看到 Smurf，直接去找选项里带“ICMP响应包大量发送”的，闭眼选它，稳拿分数！

58. 本题考查的是网络基础与信息安全模块中，恶意软件（マルウェア）为了躲避企业防火墙（Firewall）审查而常用的**端口伪装与隐蔽通信技术**。

TCP 80 端口的特殊地位：TCP 80 端口是互联网上 **HTTP（普通网页浏览）** 的标准默认端口。

防火墙策略的盲点：为了让公司内部员工能够正常浏览网页，企业的防火墙（Firewall）在绝大多数情况下默认会放行 **80 端口的流量**。

黑客的利用手法：黑客正是利用了这一点，让潜伏在电脑里的恶意软件把发往外部指挥服务器（C&C Server）的数据伪装成普通的网页浏览流量（走 TCP 80 端口），从而堂而皇之地穿透防火墙而不被拦截。

为什么“Webサイトの閲覧に使用されることから、通信がファイアウォールで許可されている可能性が高い。”（因为用于网页浏览，所以通信很有可能被防火墙允许）是正确答案？

- **深度拆解：**这精准命中了 80 端口在安全攻防中的致命软肋。正因为 80 端口是网页浏览的“绿色通道”，防火墙对它极其宽容。恶意软件借此“借鸡生蛋”，把恶意的指令通信伪装成网页流量，从而顺利通过防火墙。

“80端口与恶意软件考点速记” 口诀：

- 看到 **TCP端口80 + マルウェア**（恶意软件）→ 脑子里瞬间锁定：「**ファイアウォールで許可される**」（因为网页常用，防火墙会放行它）！

59. 本题考查的是网络安全与身份伪造模块中的经典攻击手段——**IPスプーフィング (IP Spoofing / IP 欺骗)**。

- **什么是 IP 欺骗 (IP Spoofing) ?** 在计算机网络通信中, IP 数据包的头部会记录发送方的 IP 地址。由于标准的 IP 协议在设计之初缺乏强制性的身份验证机制, 攻击者可以在发送数据包时, **故意伪造、篡改发送方的源 IP 地址 (偽の送信元IPアドレス)**, 让接收方误以为这个包是某个受信任的合法主机 (如内网机器或其他服务器) 发过来的, 从而实施越权访问或拒绝服务攻击。

“IP欺骗考点速记” 口诀:

- 看到 **IPスプーフィング (IP Spoofing)** → 脑子里瞬间锁定两个黄金词: 「偽の送信元IPアドレス」 (虚假源IP地址) + 「パケット」 (数据包)。

60. 本题考查的是网络安全与 Web 服务标准中 **XML 签名 (XML Signature)** 的核心功能与设计特性。

什么是 XML 签名 (XML署名) ? 在传统的数字签名中, 通常是对整个文件或整个二进制报文进行签名。而 XML 是一种结构化的文本标记语言。为了满足企业级应用中 “只对合同的某一部分签字、或者对同一个 XML 文档加盖多个不同部门的印章” 的需求, **XML 签名支持 “部分签名 (部分署名)” 和 “多重签名 (多重署名)”**, 允许开发人员精确指定对 XML 文档的特定元素进行加签。

为什么 “XML文書全体に対する単一の署名だけではなく, 文書の一部に対して署名を設定する部分署名や多重署名などの複雑な要件に対応する。” 是正确答案?

- **深度拆解:** 这精准命中了 XML 签名的最大技术特色。因为 XML 具有树状的标签结构, XML 签名规范 (W3C 标准) 天然支持对整个文档签名、对文档内部的某一特定子节点 (部分署名) 签名, 甚至在同一个 XML 中叠加多个人签署的签名 (多重署名)。

“XML签名考点速记” 口诀:

- 看到 **XML署名** → 脑子里瞬间锁定两个词: 「部分署名」 (部分签名) + 「多重署名」 (多重签名)。

61. 本题考查的是信息安全与 Web 服务标准中 **XML デジタル署名 (XML数字签名)** 的核心架构与设计特性。

什么是 XML 数字签名? 传统的数字签名通常是对整个二进制文件进行加签。而 XML 是一种结构化的文本标记语言。为了满足企业级应用中 “只对合同的某一部分签字、或者对同一个 XML 文档加盖多个不同部门印章” 的需求, **XML 数字签名支持对 XML 文档中指定的元素/节点进行局部签名 (指定したエレメントに対して署名する)**。

为什么 “XML文書中の, 指定したエレメントに対して署名することができる。” 是正确答案?

- **深度拆解:** 这精准命中了 XML 数字签名的最大技术特色。因为 XML 具有树状标签结构, 它不仅能够对全篇文档签名, 还能精准定位并只对文档中的某个特定元素 (指定したエレメント) 进行加签。

“XML数字签名考点速记” 口诀:

- 看到 **XMLデジタル署名** → 脑子里瞬间锁定黄金词: 「指定したエレメント」 (指定的元素)。

62. 本题考查的是 XML 数字签名 (XML Signature) 中用于定位和引用被签名对象的标准语法格式。

什么是 XML 签名中的引用？ 在 XML 数字签名中，为了明确指出究竟对文档的哪一部分（或哪个外部/内部资源）进行签名，必须使用特定的标识符来指向该对象。

它的底层规范是什么？ XML 数字签名标准（W3C 标准）规定，使用统一资源标识符——**URI (Uniform Resource Identifier)** 来指定和引用签名对象的目标（URI の形式）。

“XML 签名引用考点速记” 口诀：

- 看到 **XML 署名** 且问到“对象引用/指定” → 脑子里瞬间锁定黄金词：**「URI の形式」**。

63. 本题考查的是公钥基础设施（PKI）中 **认证局 (CA / 認証局)** 的核心职责与数字证书（電子証明書）的签发对象。

核心考点解析：

- 认证局（CA）的作用：**在公开密钥密码方式中，为了证明某个公开键确实属于特定的交易当事人（防止中间人冒充），独立的第三方机构——认证局（CA）会对其进行担保。
- CA 签发的是什么？** CA 会对交易当事人的公开键（公開かぎ / 公開鍵）附加自己的数字签名，从而生成并下发“针对公开键的电子证书（電子証明書）”。

为什么“取引当事者の公開かぎに対する電子証明書”是正确答案？

- 深度拆解：**这精准命中了数字证书（SSL 证书/用户证书）的本质。CA 的唯一工作就是证明“这个公钥的主人是谁”。因此，CA 制作和签发的是**针对公开键的电子证书（公開かぎに対する電子証明書）**。

为什么其他选项是错误项？

- 选项 **イ (取引当事者のデジタル署名)**：数字签名是交易当事人自己用私钥生成的，而不是由认证局（CA）代为制作的。
- 选项 **ウ (取引当事者のパスワード)**：密码是用户自己的隐私或由系统管理员设定的，CA 绝对不负责制作密码。
- 选项 **エ (取引当事者の秘密かぎに対する電子証明書)**：**致命陷阱！** 秘密键（私钥）必须由用户自己严密保管，绝对不能交给 CA，更不可能存在“对秘密键的电子证书”这种说法。

“派出所给身份证盖章的比喻”：

- 你在网上办事，你的**公开键**就像是你的“公开个人头像照片”。
- 公安局（**认证局 CA**）核实了你的身份后，在你的照片上盖了一个防伪钢印（数字签名），这张盖了章的照片就是“针对公开键的电子证书”。
- 至于你的**秘密键（私钥）**，就像是你藏在家里的保险柜密码，派出所怎么可能帮你制作或保存呢？

“CA 认证局考点速记” 口诀：

- 看到 **認証局 (CA)** → 脑子里瞬间锁定两个词：**「公開かぎ」**（公钥）+ **「電子証明書」**（电子证书）。

- 只要在选项里看到“对秘密键（秘密かぎ）发证书”，直接判错！CA 只给**公钥**发证书，牢记这条，拿分轻轻松松！

64. 本题考查的是企业信息安全与合规管理中，因员工擅自使用未经批准的软件、云服务或硬件而带来的安全隐患——**シャドーIT (Shadow IT / 影子IT)**。

什么是シャドーIT（影子IT）？ 它是指在企业组织中，员工（甚至各业务部门）在未获得公司信息系统部门（IT部门）批准或许可的情况下，擅自将个人的设备（如私人手机、平板）、外部云服务（如未备案的网盘、协同工具）或软件投入到日常业务办公中使用的一种现象。

它的最大危害是什么？ 因为完全游离于公司 IT 部门的监控和统一管理之外（像藏在阴影里一样），极易导致企业核心机密泄露、恶意软件入侵以及数据资产失控。

题目中的描述完美勾勒出了影子IT的定义：“在业务利用中，本应需要公司信息系统部门的许可，却在没有获得许可的情况下擅自被使用的设备、云服务或软件”。“影子（Shadow）”一词形象地形容了它不公开、不受监管的特性。

“影子IT考点速记” 口诀：

- 看到“許可を得ずに勝手に利用”（没有获得许可、擅自使用云服务或设备）→ 脑子里瞬间锁定：「シャドーIT」！

65. 本题考查的是信息安全与系统漏洞模块中极具破坏力的经典漏洞——**バッファオーバーフロー (Buffer Overflow / 缓冲区溢出)**。

什么是缓冲区（Buffer）？ 程序在运行时代留的、用来临时存放输入数据的内存空间（比如规定只能装 10 个字节）。

什么是缓冲区溢出（Buffer Overflow）？ 如果程序在接收用户输入时**缺乏严格的长度检查（文字数制限の欠如）**，攻击者就可以故意输入超长的数据（比如塞进去 100 个字节）。由于空间不够，多出来的数据就会“溢出”并覆盖掉旁边紧邻的内存区域（如返回地址、控制寄存器）。攻击者借此机会篡改程序执行流程，从而强制运行恶意的汇编代码或提权。

为什么“プログラムが用意している入力用のデータ領域を超えるサイズのデータを入力することで、想定外の動作をさせる。”是正确答案？

- **深度拆解：**这精准命中了缓冲区溢出的本质——输入的尺寸（サイズ）超过了程序准备的输入数据区域（データ領域 / 缓冲区），从而溢出并导致程序出现非预期的崩溃或被恶意利用（想定外の動作をさせる）。

“缓冲区溢出考点速记” 口诀：

- 看到 **バッファオーバーフロー (Buffer Overflow)** → 脑子里瞬间锁定两个词：「データ領域を超えるサイズ」（超出数据区域的大小）+ 「想定外の動作」（非预期动作）。

只要在考卷里看到输入数据太大把内存撑破了，闭眼选它，稳拿分数！

66. 本题考查的是 **DNSキャッシュポイズニング (DNS缓存投毒)** 的攻击机制与影响范围的逻辑推演。

- **核心考点解析：**

- **谁被投毒了？** 题干明确指出：“攻撃者が用意したサーバXのIPアドレスが、A社WebサーバのFQDNに対応するIPアドレスとして、**B社DNSキャッシュサーバに記憶された**”（攻击者准备的服务器X的IP地址，作为A社Web服务器的域名解析结果，**被记录在了 B社的 DNS 缓存服务器中**）。
- **谁会中招？** 既然是 **B社** 的 DNS 缓存服务器被污染了，那么所有依赖这个缓存服务器来进行名字解析（名前解決）的人，当他们尝试访问时，就会被带沟里去。题目接着限定：“A社、B社の各従業員は自社のDNSキャッシュサーバを利用して名前解決を行う”（A社和B社各自的员工使用**自社**的DNS缓存服务器）。因此，**B社**的员工在查域名时，就会从被污染的 B社 DNS 服务器拿到虚假 IP，从而被误导访问到攻击者的服务器 X。

为什么“A社WebサーバにアクセスしようとするB社従業員”是正确答案？

- **深度拆解：**
 - i. 目标网站是：**A社 Web服务器**（即大家想要访问的目标是 A社）。
 - ii. 污染的源头在：**B社 DNS缓存服务器**（B社的DNS被投毒了）。
 - iii. 受害者是谁？是**B社**的员工（因为他们用的是被污染的 B社 DNS，所以当他们想去访问 A社时，被 B社 的假DNS指引到了攻击者的服务器 X）。

“邻居村子路标被涂改的比喻”：

- A村子开了一家大超市（**A社Web服务器**）。
- 坏人偷偷潜入 **B村** 的村口，把村里的指示路牌（**B社DNS服务器**）给偷偷改了，指着去A村的方向其实通往坏人的陷阱。
- **A村的村民**出门走的是自己村的真路牌，所以没事。
- 只有 **B村的村民**（**B社従業員**）出门时信任了自家被改掉的路牌，结果兴冲冲地跑去了 A村（**A社Webサーバにアクセスしようとする**），却掉进了坏人的陷阱。
- 所以，受害者就是：“想去A村，结果被自家（B社）坏路牌坑了的 B社员工”！

“DNS缓存投毒影响题解题口诀”：

- 看到这类题目，直接抓两个核心：
 - i. 谁的 DNS 记错了（**在哪家公司的 DNS**） $\rightarrow$ 决定了**谁的员工**会中招！
 - ii. 想要访问谁 $\rightarrow$ 决定了访问的目标。
- 本题中 “**B社DNSに記憶された**” 对应 “**B社従業員**”，锁定这一条，直接秒杀！

67. 本题考查的是信息安全与计算机犯罪领域中一个非常基础但容易与“白色黑客/测试”混淆的术语——**クラッキング (Cracking / 恶意破解/黑客攻击)**。

什么是 **Cracking**（恶意破解/黑客攻击）？与之相对的是“Hacking”（在广义上可以指技术探索，但早期的白帽子黑客也常被称作 Hacker）。而 **Cracking** 特指那些怀揣恶意（悪意をもって）、未经授权擅自闯入计算机系统（不正侵入）、进行数据窃取、篡改或破坏的犯罪行为。

为什么“悪意をもってコンピュータに不正侵入し、データを盗み見たり破壊などを行う。”是正确答案？

- **深度拆解**：这精准命中了 Cracking（黑客攻击/恶意破解）的核心定义：带有恶意（悪意をもって）、非法入侵（不正侵入）、以及偷看或破坏数据（データを盗み見たり破壊などを行う）。这就是标准的网络恶意破坏行为。

“Cracking 考点速记” 口诀：

- 看到 **クラッキング (Cracking)** → 脑子里瞬间锁定两个核心词：「**悪意**」（恶意）+ 「**不正侵入・破壊**」（非法入侵与破坏）。

68. 本题考查的是生物特征认证（バイオメトリクス認証，如指纹、人脸识别）中两个核心错误率指标的联动关系。

FRR (False Rejection Rate / 本人拒否率)：明明是本人来刷脸，系统却误判为“这不是本人”而拒绝放行的概率（误伤好人）。

FAR (False Acceptance Rate / 他人受入率)：明明是陌生坏人来刷脸，系统却误判为“这是本人”而放行的概率（放过坏人）。

判定阈值（しきい値）的跷跷板效应：系统的严格程度（阈值）是可以调节的。如果你把系统调得极其严厉：

- 坏人想混进来？门都没有 → **FAR 下降（减少）**。
- 但是，本人稍微化了个妆、或者手指沾了点灰，系统也认不出来了，好人被疯狂拒绝 → **FRR 上升（增大）**。
- 反之，如果把系统调得**极其宽容**：本人进得去了（FRR减少），但坏人也更容易混进来了（FAR增大）。
- 因此，**FRR 和 FAR 是一对“此消彼长”的跷跷板**：你想让误伤好人的概率（FRR）减少，放过坏人的概率（FAR）就会增大；反之亦然。

为什么“FRRを減少させると、FARは増大する。”是正确答案？

- **深度拆解**：根据上述的“跷跷板原理”，如果你调整系统的判定阈值，使得本人被拒绝的概率（FRR减少，即对好人更宽容），那么系统大门敞开，坏人混进来的概率（FAR增大，即对坏人也更宽容）就会随之上升。两者呈反向联动关系。

“生物认证考点速记” 口诀：

- 看到 **FRR 和 FAR** → 脑子里瞬间想到「跷跷板」！
- 它们永远是**反方向（一个降，另一个必升）**。选项里只要看到“同增同减”或者“独立无关”的直接排除，锁定“一个减少、另一个增大”，稳拿分数！

69. 本题考查的是信息安全领域中用于描述网络攻击演练与防御阶段的经典模型——**サイバーキルチェーン (Cyber Kill Chain / 网络杀伤链)**。

什么是サイバーキルチェーン（网络杀伤链）？ 最初由洛克希德·马丁公司提出，它从攻击者的视角（攻撃者の視点から）出发，将一次完整的网络攻击行为拆解为多个顺序进行的阶段（从最初的侦察、武器化、投递、利用、安装、命令与控制，到最后的达成目标）。

它的核心价值是什么？ 帮助防御方在攻击的各个环节中“断开链条”（Kill the chain），从而在黑客达成最终目的之前拦截攻击。

为什么“攻撃者の視点から, 攻撃の手口を偵察から目的の実行までの段階に分けたもの”是正确答案？

- **深度拆解：**这精准命中了网络杀伤链（Cyber Kill Chain）的定义。它完美契合了“从攻击者视角出发（攻撃者の視点から）”、“将攻击手法从侦察到目的执行分阶段（偵察から目的の実行までの段階に分けたもの）”的本质特征。

“网络杀伤链考点速记” 口诀：

- 看到 **サイバーキルチェーン** → 脑子里瞬间锁定两个黄金词：「**攻撃者の視点**」（攻击者视角）+ 「**偵察から目的の実行までの段階**」（从侦察到目的执行的阶段）。

70. 本题考查的是信息安全中两大密码体系——**共通鍵暗号方式 (对称密钥密码)** 与 **公開鍵暗号方式 (公开密钥/非对称密钥密码)** 的核心特性及其在实际网络传输中的完美结合。

◦ **核心考点解析：**

- **混合密码系统 (Hybrid Cryptosystem)：**在现代安全通信（如 HTTPS / TLS）中，为了兼顾“安全性”与“传输速度”，实际采用的是组合拳：

1. 首先利用**公開鍵暗号方式**在不安全的网络中安全地交换一把临时的**共通鍵（对称密钥）**。
2. 随后，真正庞大的正文数据加密全部交给速度极快的**共通鍵暗号方式**来完成。

为什么“通信の開始時に共通鍵を公開鍵暗号方式で暗号化して相手に送り, データの暗号化を共通鍵暗号方式で行う方法が実用化されている。”是正确答案？

- **深度拆解：**这精准命中了现代互联网安全通信（TLS/HTTPS）的底层实现标准。因为公钥密码计算慢、但能安全传递钥匙；对称密码计算快、但无法直接安全传递。于是两者的结合成为业界王牌：先用公钥密码安全护送共通键，再用共通键高速加密海量数据。完美契合题意！

“用贵重的保险箱运送普通房间钥匙的比喻”：

- 你和远方的朋友要秘密通信。共通键就像是你们房间的普通木门钥匙（速度极快但直接在网上扔过去会被偷）。
- 怎么办呢？你们先用一把极其坚固的**带锁密码箱（公开密钥加密）**，把这把普通钥匙安全地锁在里面寄给对方。
- 等对方拿到钥匙后，接下来的千言万语（大量数据），就直接用这把普通钥匙开门运送（**共通键加密**）了！
- 这种“先用公钥传钥匙、再用对称加密传数据”的黄金组合，就是考试中的永恒考点！

“混合加密考点速记” 口诀：

- 看到「共通鍵を公開鍵で暗号化して送り」（用公钥加密发送对称密钥） → 闭眼选它！

71. 本题考查的是密码学中用于数据完整性校验和数字签名的核心哈希算法——**SHA-1 (Secure Hash Algorithm 1)**。

什么是哈希函数（Hash Function / ハッシュ関数）？ 它可以把任意长度的输入数据转换成固定长度的输出数据（哈希值/摘要）。

SHA-1 的核心特征：它是由美国国家标准技术研究所（NIST）设计的加密哈希函数，能够将输入数据转化为 **160 比特（160ビット）** 的输出数据。它常被用于数字签名和防篡改检测（改ざんの検出）中。

为什么“160 ビットの出力データを生成し, 改ざんの検出に利用するアルゴリズム”是正确答案？

- 深度拆解：**这精准命中了 SHA-1 的两个硬性指标：1. 输出长度是 160 比特（160ビット）；2. 它的主要用途是验证数据完整性、检测文件是否被恶意篡改（改ざんの検出）。

处理问题的排查表（常见哈希与加密算法对比表）

算法名称 (日语原件)	输出长度 (比特)	核心应用场景	考试中的识别关键词
SHA-1	160 比特 (160ビット)	防篡改检测、数字签名摘要	160ビット、改ざんの検出
MD5	128 比特	数据完整性校验	128ビット
SHA-256	256 比特	高安全性数字签名与区块链	256ビット

72. 考查的是密码学与信息安全中经典的密码破解手法分类——**ブルートフォース攻撃 (Brute-force Attack / 暴力破解攻击)**。

- 什么是ブルートフォース攻撃（暴力破解/穷举攻击）？** 它是指攻击者在已知一段密文（暗号文）和对应的部分明文（或者通过系统逐个尝试）的情况下，利用计算机的超强算力，把所有可能的密钥组合从头到尾**进行全排列、总动员式的穷举尝试（総当たり）**，直到试出正确的那把钥匙为止。

为什么“与えられた1組の平文と暗号文に対し, 総当たりで鍵を割り出す。”是正确答案？

- 深度拆解：**这精准命中了暴力破解（Brute-force）的字面和技术本质。它通过“总动员（総当たり）”的方式去尝试所有可能的组合来找出加密钥匙（鍵を割り出す）。

“暴力破解考点速记” 口诀：

- 看到 **ブルートフォース攻撃 (Brute-force)** → 脑子里瞬间锁定两个黄金词：**「総当たり」**（总动员/穷举）+ **「鍵を割り出す」**（找出钥匙）。

73. 本题考查的是信息安全与漏洞利用模块中的核心概念——**エクスプロイトコード (Exploit Code / 漏洞利用代码)**。

- **什么是漏洞（Vulnerability / 脆弱性）？** 软件或硬件中存在的安全缺陷。
- **什么是漏洞利用代码（Exploit Code）？** 当漏洞被发现后，黑客或研究人员编写的、专门用来触发并利用这些软件或硬件漏洞（脆弱性を利用する）从而实现越权访问、执行恶意命令的程序或脚本。
- **为什么“ソフトウェアやハードウェアの脆弱性を利用するために作成されたプログラム”是正确答案？**
 - **深度拆解：**这精准命中了 Exploit Code（漏洞利用代码）的字面及技术本质：利用（利用する）软件或硬件的脆弱性（脆弱性），专门为此目的而编写的程序（作成されたプログラム）。完美契合！

“Exploit 考点速记” 口诀：

- 看到 **エクスプロイトコード** → 脑子里瞬间锁定两个黄金词：**「脆弱性を利用」**（利用漏洞）+ **「プログラム」**（程序）。

74. 本题考查的是信息安全中一种经典的社会工程学与文件伪装手段——RLO (Right-to-Left Override) 机制。

什么是 RLO（从右到左重排控制符）？ 在计算机编码（如 Unicode）中，有些语言（如阿拉伯语、希伯来语）是从右向左书写的。操作系统为了支持这些语言，提供了一个特殊的控制字符——**RLO (Right-to-Left Override)**。

它的安全威胁是什么？ 攻击者会恶意利用这个控制字符来**篡改和伪装文件的扩展名（ファイル名の拡張子を偽装する）**。例如，一个名为 `virus.gjp.exe` 的恶意程序，如果中间插入了 RLO 字符，在 Windows 资源管理器里就会被强行倒过来显示为 `virus.exe.pjg`。用户误以为这是一个无害的图片（.pjg）而点开，从而中招。

为什么“文字の表示順を変える制御文字を利用し、ファイル名の拡張子を偽装する。”是正确答案？

- **深度拆解：**这精准命中了 RLO 的技术本质与攻击手法。利用改变文字显示顺序的控制字符（文字の表示順を変える制御文字），把文件名倒过来写，从而伪装文件的扩展名（拡張子を偽装する）

“RLO 考点速记” 口诀：

- 看到 **RLO (Right-to-Left)** → 脑子里瞬间锁定两个黄金词：**「表示順を変える制御文字」**（改变显示顺序的控制字符）+ **「拡張子を偽装」**（伪装扩展名）。

75. 本题考查的是网络安全与 SSL/TLS 协议中的经典降级攻击——バージョンロールバック攻撃 (Version Rollback Attack / 版本回滚攻击)。

什么是版本回滚攻击？ 在 SSL/TLS 协议的握手初期（Handshake），客户端和服务端会商量使用哪个版本的加密协议（例如最新最安全的 TLS 1.3 还是老旧脆弱的 SSL v3）。

攻击原理：中间人攻击者（Man-in-the-Middle）利用 SSL/TLS 实现上的漏洞，在通信路径中强行干预、删改或伪造握手消息，**强制（強制する）让客户端和服务端放弃使用现代的高强度加密方**

式，退回到（回滚到）存在严重漏洞的弱加密或旧版本协议（弱い暗号化通信方式 / 旧版本）。一旦降级成功，攻击者便能轻松解密通信内容。

“版本回滚攻击考点速记” 口诀：

- 看到 バージョンロールバック (Version Rollback) → 脑子里瞬间锁定两个黄金词：「弱い暗号化通信方式を強制する」（强制使用弱加密/旧版本）。

76. 本题考查的是高级持续性威胁（APT）中一种非常狡猾的主动防御规避与定向攻击手段——**水飲み場型攻撃 (Watering Hole Attack / 水坑攻击)**。

什么是水坑攻击（Watering Hole Attack）？ 它的名字来源于自然界的掠食动物（如狮子）不在水源处直接追捕猎物，而是守候在动物们每天必经的“水坑”旁等待猎物上钩。

在网络安全中如何运作？ 攻击者首先去调查并摸清目标组织（如某特定企业或政府部门）的员工平时最经常、最频繁访问的合法网站（比如行业新闻网、供应商网站）。接着，黑客利用漏洞偷偷潜入这些合法网站，在里面植入恶意的攻击代码。当目标公司的员工再次像往常一样访问这些熟悉的网站时，便会在不知不觉中触发陷阱并感染恶意软件。

为什么“標的組織の従業員が頻繁にアクセスするWebサイトに攻撃コードを埋め込み、標的組織の従業員がアクセスしたときだけ攻撃が行われるようにする。”是正确答案？

- 深度拆解：**这精准命中了水坑攻击（Watering Hole）的精髓——埋伏在目标员工经常去的网站（頻繁にアクセスするWebサイト）里，等他们自己送上门访问时触发攻击（アクセスしたときだけ攻撃が行われる）。这正是“水坑”的生动写照。

“水坑攻击考点速记” 口诀：

- 看到 水飲み場型攻撃 (Watering Hole) → 脑子里瞬间锁定两个黄金词：「頻繁にアクセスするWebサイト」（频繁访问的网站）+ 「攻撃コードを埋め込み」（埋入攻击代码）。

77. 本题考查的是 DNS 安全与拒绝服务攻击（DoS / 缓存投毒衍生攻击）中的一种经典手法——**ランダムサブドメイン攻撃 (Random Subdomain Attack / 随机子域攻击)**。

攻击是如何运作的？ 攻击者通过脚本随机生成海量的、压根不存在的 A 社子域域名（例如 `asdfgh.a-company.co.jp`）。然后，通过大量第三方的 DNS 缓存服务器向 **A 社的权威 DNS 服务器（A 社ドメインの権威DNSサーバ）** 发起疯狂的查询。

攻击的最终目的是什么？ A 社的权威 DNS 服务器为了处理这些铺天盖地、且永远找不到答案的随机查询请求，耗尽了所有的 CPU、内存和网络带宽资源，最终导致正常用户的合法域名解析请求无法响应，陷入**服务不可用状态（サービス不能 / DoS）**。因此，黑客真正的攻击靶心（標的）就是 A 社的权威 DNS 服务器。

为什么“A社ドメインの権威DNSサーバ”是正确答案？

- 深度拆解：**这精准命中了该攻击的最终受害者。因为所有的随机子域（Subdomain）都属于 A 社的域名，第三方缓存服务器查不到就会层层上溯，最终全部砸向负责管理 A 社域名最终解析的**权威 DNS 服务器（権威DNSサーバ）**。这导致 A 社的权威 DNS 服务器因过载而瘫痪。

“随机子域攻击考点速记” 口诀：

- 看到 **ランダムサブドメイン攻撃** → 脑子里瞬间锁定终极靶心：「**權威DNSサーバ**」（权威 DNS 服务器）。

78. 本题考查的是云服务（Cloud Service）特有的一种新型安全威胁——**EDoS 攻撃 (Economic Denial of Service / 经济拒绝服务攻击 / 经济拒绝服务)**。

什么是 EDoS 攻击 (Economic Denial of Service) ? 在传统的 DoS 攻击中，黑客的目的是让服务器瘫痪、无法提供服务。而在云计算时代，由于绝大多数云服务采用的是按量付费、弹性计费（従量課金）的商业模式，黑客改变了策略：他们不一定要把服务器彻底搞崩溃，而是通过发送海量合法的或自动化的垃圾请求，迫使云服务器疯狂调用计算资源、自动扩容。

它的最终杀伤力是什么？ 服务器虽然没瘫痪，但由于资源被大量无休止地消耗（リソースを大量消費），云服务商会开出巨额的账单，从而达到给企业造成沉重经济损失（経済的な損失を目的とする）的恶毒目的。

传统的 DoS 攻击就像是坏人直接把出租车的轮胎扎破，让你彻底开不动（车瘫痪了）。

而 **EDoS 攻击 (Economic DoS)** 就像是坏人雇了一群机器人，坐上你的出租车（云端资源），命令司机在全城绕行三天三夜。

虽然车没坏，但因为你的车是按公里计费（従量課金）的，行程结束后，司机递给你一张天文数字的天价账单，直接把你搞破产（**经济上的巨大损失**）！这种“用巨额账单整垮你”的招数，就是 EDoS 攻击！

“EDoS 攻击考点速记” 口诀：

- 看到 **EDoS (Economic DoS)** → 脑子里瞬间锁定两个黄金词：「**経済的な損失**」（经济损失）+ 「**従量課金 / リソースを大量消費**」（按量付费 / 消耗海量资源）。

79. 本题考查的是信息安全中用于验证消息完整性与防篡改的核心密码学机制——**メッセージ認証碼 (MAC / 消息认证码)** 的底层生成原理。

什么是消息认证码 (MAC) ? 它是一种用于确认消息没有被篡改、并且确实是由持有密钥的发送方所发送的技术。

它是如何生成的？ 在密码学实践中，生成消息认证码 (MAC) 时往往会结合密钥，利用共通键暗号方式（对称加密/区块加密，如 AES、CBC-MAC）对消息进行加密处理来生成校验码。

题目中提到“从消息出发，利用区块加密（ブロック暗号を用いて）生成”，这正是通过对称区块加密来构造 MAC（如 CBC-MAC 算法）的标准技术特征。

“MAC 考点速记” 口诀：

- 看到「**ブロック暗号を用いて生成**」（利用区块加密生成）+ 「**改ざんされていないか確認**」（确认没有被篡改）→ 脑子里瞬间锁定：「**メッセージ認証符号**」！

80. 本题考查的是网络安全与僵尸网络（Botnet）架构中核心指挥中枢——**C&C サーバ (Command and Control Server / 指令与控制服务器)** 的职责。

什么是 C&C 服务器？ 在僵尸网络中，黑客（攻击者）不会直接一台台去手动操控被感染的电脑，而是通过互联网设立一个中央控制服务器，简称 **C&C 服务器**。

它的核心作用是什么？ 潜伏在受害者电脑里的恶意软件（マルウェア）会定时主动向这个 C&C 服务器“打报告”、获取最新指令，而 C&C 服务器则负责向这些远程受控木马下达各种**信息收集、发动 DDoS 攻击等恶意活动指令（情報収集及び攻撃活動を指示する）**。

为什么“遠隔操作が可能なマルウェアに、情報収集及び攻撃活動を指示する”是正确答案？

- **深度拆解：**这精准命中了 C&C 服务器（Command and Control Server）的字面和功能本质。它的英文原意就是“指挥与控制”，其核心使命就是向具备远程操控能力的恶意软件下达搜集情报、发起攻击等指令（情報収集及び攻撃活動を指示する）。

“C&C 服务器考点速记” 口诀：

- 看到 **C&Cサーバ** → 脑子里瞬间锁定黄金词：**「指示する」**（发号施令/下达指示）+ **「マルウェアに」**（对恶意软件）。

81. 本题考查的是基于散列函数链（Hash Chain）的挑战-应答式一次性密码认证系统——S/KEY ワンタイムパスワード。

什么是 S/KEY 一次性密码？ 它是一种不需要硬件令牌、仅靠软件算法实现的“一次性密码（One-Time Password）”系统。

它的核心运作逻辑（哈希链）： 用户设置一个初始口令（Passphrase），系统对其连续进行 N 次哈希运算（Hash），得到一个列表。登录时，服务器保存的是**上一次使用过（或验证过）的哈希值**，而客户端提交的是这一次的动态口令。服务器收到后，对其进行一次哈希运算，看其结果是否等于服务器端记录的**前一次的使い捨てパスワード（前一次的一次性密码）**，以此来验证客户端的合法性。

为什么“サーバはクライアントから送られた使い捨てパスワードを演算し、サーバで記憶している前回の使い捨てパスワードと比較することによって、クライアントを認証する。”是正确答案？

- **深度拆解：**这精准命中了 S/KEY 的核心工作原理。由于哈希函数的“单向性”，客户端提交当次密码后，服务器将其带入算法计算一次（演算し），并与自己数据库里记录的上一次（前回）的口令进行比对（比較），如果算出来的结果和上一次吻合，就证明客户端确实持有正确的密码链，从而验证通过。

“S/KEY 考点速记” 口诀：

- 看到 **S/KEY** → 脑子里瞬间锁定黄金词：**「前回の使い捨てパスワードと比較」**（与前一次的一次性密码进行比较）。

82. 本题考查的是硬件与密码学安全中一种高级的物理攻击手段——サイドチャネル攻撃 (Side-Channel Attack / 侧信道攻击)。

什么是侧信道攻击？ 在传统的密码学中，密码算法本身的数学理论是极其严密的，正面强攻几乎不可能。但是，当芯片在物理世界里运行这些加密算法时，会不可避免地向外界泄漏一些物理特征。

它的运作原理是什么？ 攻击者通过测量物理设备在运算过程中的**处理时间（処理時間）、消耗电流（消費電流）、电磁辐射甚至是错误信息（エラーメッセージ）**，来反向推算出内部的机密密钥（物理デバイスから得られる物理量から、機密情報を得る）。

为什么“暗号アルゴリズムを実装した攻撃対象の物理デバイスから得られる物理量（処理時間や消費電流など）やエラーメッセージから、攻撃対象の機密情報を得る。”是正确答案？

- **深度拆解**：这精准命中了侧信道攻击（Side-Channel Attack）的学术定义。它不走逻辑正门，而是通过观察物理设备在运算时露出的“侧面马脚”（处理时间长短、耗电量大小、电磁波动等物理量），把密钥匙给偷出来。

“侧信道攻击考点速记” 口诀：

- 看到 **サイドチャネル攻撃** → 脑子里瞬间锁定黄金词：「物理量」、「消費電流」（消耗电流）或「処理時間」（处理时间）。

83. 本题考查的是 Web 应用安全中经典的路径遍历漏洞与攻击手法——**ディレクトリトラバーサル攻撃 (Directory Traversal Attack / 目录遍历攻击)**。

什么是目录遍历攻击？ 当 Web 应用程序在接收用户输入的字符串来拼接、读取文件时（例如下载或查看某张图片、某个文档），如果没有对输入内容进行严格的过滤或检查。

它的攻击原理是什么？ 攻击者会在输入字符串中恶意掺入代表上一级目录的特殊字符（在多数操作系统中为 `../`），从而突破原本限定的公开目录，强行越权访问服务器上原本不公开的系统核心敏感文件（例如 Linux 下的 `/etc/passwd`）。

为什么“入力文字列からアクセスするファイル名を組み立てるアプリケーションに対して、攻撃者が、上位のディレクトリを意味する文字列を使って、非公開のファイルにアクセスする。”是正确答案？

- **深度拆解**：这精准命中了目录遍历（Directory Traversal）的技术本质。它利用了“上位目录的字符串（例如 `../`）”去拼接和访问非公开文件（非公開のファイルにアクセスする）。这正是目录遍历攻击的字面定义和运作方式。

“目录遍历考点速记” 口诀：

- 看到 **ディレクトリトラバーサル** → 脑子里瞬间锁定两个黄金词：「上位のディレクトリ」（上位目录 / `../`）+ 「非公開のファイル」（非公开文件）。

84. 本题考查的是数字证书（尤其是 EV SSL 证书，Extended Validation SSL Certificate）中主体字段（Subject Field）的构成细节。

什么是 EV SSL 证书？ 它是验证级别最高的 SSL/TLS 证书，不仅加密通信，还会对网站背后的运营主体进行极其严格的法人身份审核。

什么是组织名称（Organization Name, O）？ 在证书的サブジェクト（Subject / 主体）字段中，Organization Name (O) 记载的必须是该网站真正的运营实体/企业组织的官方名称（Web サイトの運営団体の組織名），从而让访客一眼就能确认这个网站到底是谁在经营。

“EV SSL 证书考点速记” 口诀：

- 看到 **EV SSL 証明書** 且问 **Organization Name** → 脑子里瞬间锁定：「運営団体の組織名」（运营团体的组织名）。

85. 本题考查的是网络安全中一种针对网银用户的恶意浏览器篡改攻击——**Man-in-the-Browser (MitB / 浏览器中间人攻击)**。

什么是 MitB 攻击？ 攻击者通过恶意软件（マルウェア）悄悄潜入用户的个人电脑并寄生在 Web 浏览器内部。

它的核心运作方式是什么？ 当用户登录合法的网上银行（Internet Banking）并准备进行正常的转账汇款时，潜伏在浏览器里的恶意软件会实时监控，并在用户不知情的情况下，**暗中篡改浏览器发送出去的汇款金额、收款账号等关键数据（振込先などのデータを改ざんする）**。

为什么“PCに侵入したマルウェアが、利用者のインターネットバンキングへのログインを検知して、Webブラウザから送信される振込先などのデータを改ざんする。”是正确答案？

- **深度拆解：**这精准命中了浏览器中间人攻击（MitB）的精髓。恶意软件潜伏在用户的电脑/浏览器内部（PCに侵入したマルウェア），在用户操作网银时，直接在浏览器端偷梁换柱，篡改转账目的地等核心数据（データを改ざんする）。

“网购时被寄生在购物车里的内鬼偷换收货地址的比喻”：

- 你自己在电脑上清清白白地登录了网银，准备给朋友转账 100 元。
- 但是，你的电脑里藏了一个小偷木马（PCに侵入したマルウェア）。就在你点击发送的一瞬间，这个小偷在浏览器内部偷偷把收钱的人改成了坏人的账号（振込先などのデータを改ざんする）。
- 你以为是在和银行安全通信，实际上浏览器内部已经被内鬼劫持了。这种藏在浏览器里做手脚的招数，就是 **Man-in-the-Browser (MitB)!**

“MitB 考点速记” 口诀：

- 看到 **Man-in-the-Browser** → 脑子里瞬间锁定两个黄金词：「PCに侵入したマルウェア」（侵入PC的恶意软件）+ 「データを改ざん」（篡改数据）。

86. 本题考查的是恶意软件分类中经典的僵尸网络核心程序——**ボット (Bot)**。

什么是ボット (Bot) ？ 它是一种潜伏在大量计算机中的恶意程序（不正プログラム）。它最大的特征是平时安安静静，一旦接收到来自攻击者的远程指令（远隔操作），就会像傀儡一样听从指挥，成群结队地同时发动拒绝服务攻击（DDoS 攻撃）。

为什么“ボット (Bot)” 是正确答案？

- **深度拆解：**这精准命中了 Bot（僵尸程序）的定义。它会感染大量计算机（多数のコンピュータに感染し）、接受远程指令（遠隔操作で攻撃者から指令を受け）、一齐发动 DDoS 攻击（DDoS攻撃などを一斉に行う）。完美契合！

为什么其他选项是错误项？

- ハニーポット (Honeypot): 这是诱捕黑客的“蜜罐”防御系统，不是恶意程序。
- マクロウイルス (Macro Virus): 这是寄生在 Office 宏脚本里的病毒，主要通过文档传播。

- **ワーム (Worm)**: 蠕虫病毒主要靠自我复制在网络中传播, 不一定侧重于受远程控制并发起DDoS。

“Bot 考点速记” 口诀:

- 看到「**多数のコンピュータに感染**」+「**遠隔操作でDDoS**」→ 脑子里瞬间锁定:「**ボット**」(Bot)。

87. 本题考查的是计算机病毒 (Computer Virus) 的基本定义、传播条件及其行为特征。

什么是病毒的传染条件? 病毒通常寄生在合法的程序文件中。如果在计算机内存中存在携带病毒的程序文件, 但只要用户没有主动去执行/启动这个文件 (利用者が意図的にファイルを起動しない限り), 病毒就无法执行其代码, 也就不会传染给其他系统。

为什么“ウイルスの潜伏しているプログラムファイルがコンピュータ内に存在している場合であっても, コンピュータ利用者が意図的にファイルを起動しない限りほかのシステムに伝染しない。” 是正确答案?

- **深度拆解**: 这精准命中了计算机病毒的传染机制。病毒本质上是一段需要被“运行”才能触发的程序代码。如果只静静地躺在硬盘里 (文件存在), 用户不去点它、不运行它, 它就无法自我复制或传染给其他系统。

“病毒特性考点速记” 口诀:

- 看到 **病毒传染条件** → 脑子里瞬间锁定:「**起動しない限り伝染しない**」(只要不启动就不会传染)。

88. 本题考查的是信息安全中针对密码盗取的三大经典攻击手法 (字典攻击、嗅探、暴力破解) 与其对应的有效防御策略之间的逻辑配对。

针对**辞書攻撃** (猜常见词), 对策是“设置难以猜测的密码 (推測されにくいパスワードを設定する)”。

针对**スニффイング** (网络偷听明文), 对策是“将密码加密后发送 (パスワードを暗号化して送信する)”。

针对**ブルートフォース攻撃** (无限次穷举), 对策是“限制登录尝试次数 (ログインの試行回数に制限を設ける)”。

三组配对完美契合防御逻辑!

看到 **スニффイング (嗅探)** → 闭眼连线:「**暗号化して送信**」(加密发送)。

看到 **ブルートフォース (暴力破解)** → 闭眼连线:「**試行回数に制限**」(限制尝试次数)。

“组合矩阵题考点速记” 口诀:

- 看到 **スニффイング (嗅探)** → 闭眼连线:「**暗号化して送信**」(加密发送)。
- 看到 **ブルートフォース (暴力破解)** → 闭眼连线:「**試行回数に制限**」(限制尝试次数)。

89. 本题考查的是网络营销与隐私追踪技术中的经典概念——**Webビーコン (Web Beacon / 网络信标 / 网页像素)**。

什么是 Web ビーコン（网络信标）？ 它是一种嵌入在网页（Web 页面）或 HTML 格式电子邮件中的、体积极其微小（通常为 1x1 像素）的透明图像文件（画像）或脚本。

它的核心作用是什么？ 当用户浏览该网页或打开邮件时，浏览器会自动向服务器请求加载这个图像。通过这个加载动作，网站运营方可以收集用户的访问动向、IP 地址、访问时间等统计信息（利用者のアクセス動向などの情報を収集するためにWebページなどに埋め込まれた画像）。

“Web ビーコン考点速记” 口诀：

- 看到 **Web ビーコン** → 脑子里瞬间锁定两个黄金词：**「アクセス動向の収集」**（收集访问动向）+ **「埋め込まれた画像」**（嵌入的图片）。

90. 本题考查的是由日本经济产业省与 IPA（信息处理推进机构）共同制定的《サイバーセキュリティ経営ガイドライン》（网络安全经营指南）中，关于企业经营者（CEO/管理层）在网络安全治理方面应尽职尽责的核心原则。

网络安全不仅是 IT 技术部门的事，更是**经营者（高层管理人员）必须亲自领导和统筹**的战略问题。

指南明确指出，经营者必须在预算分配、人才培养、供应链管理、事故响应等方面承担责任，例如：为了确保企业具备抵御风险的能力，**经营者必须下达指令去确保适当的预算、维持和改善适当的待遇（適切な処遇の維持・改善や適切な予算の確保を指示する）**，以招募和留住网络安全专业人才。

为什么其他选项是错误项？

- 选项 ア (为了防止 CISO 独断专行，任命没有经营级权限的人当 CISO)：大错特错。CISO（首席信息安全官）必须具备足够的权力和经营视野，怎么能故意选个没权限的人？
- 选项 イ (为了防止攻击被模仿，命令外部绝对不提供受攻击的信息)：大错特错。指南鼓励企业间进行信息共享与联动合作（信息披露与联合防御），而不是闭门造车、隐瞒不报。
- 选项 エ (在签订商业合同时，禁止自社去实施审计或掌握合作伙伴的安全对策状况)：大错特错。供应链安全（サプライチェーンセキュリティ）要求企业必须对业务伙伴的安全状态进行监督和管理，而不是“禁止掌握”。

“经营指南考点速记” 口诀：

- 看到 **経営ガイドライン (经营指南)** → 脑子里瞬间寻找正面、积极、老板该干的宏观大事：**「適切な予算の確保」**（确保适当预算）或 **「人材の確保」**（确保人才）。

91. 本题考查的是信息安全 CIA 三要素（Confidentiality, Integrity, Availability）中——**可用性（Availability / 可用性）**的概念及其遭到破坏（損なわれた）的典型事故场景。

核心考点解析：

- **什么是可用性（Availability）？** 它是指授权用户需要时能够正常访问系统、数据或服务的特性（即“随时能用、不会瘫痪”）。
- **什么是可用性受损？** 只要导致系统无法运行、服务中断、用户无法访问，就属于可用性遭到破坏。

为什么“**停電によってシステムが停止した。**”是正确答案？

- **深度拆解：**系统因停电而停止运行（システムが停止した），导致合法用户无法再使用该系统。这直接破坏了业务的连续性和随时访问的特性，完美对应了“可用性（Availability）受损”的定义。

为什么其他选项是错误项？

- 选项 イ (权限设置错误导致数据被无权者公开)：这破坏了数据的机密性（Confidentiality），属于机密性受损。
- 选项 ウ (不正アクセスによってデータ漏えい)：这同样是机密性遭到破坏（Confidentiality）。
- 选项 エ (程序Bug导致数据被错误更新)：这破坏了数据的准确和真实性，属于完整性（Integrity）受损

92. 本题考查的是信息安全管理（ISO/IEC 27000 系列及 JIS Q 27001）中风险评估的核心三要素关系：风险（Risk）、威胁（Threat）、脆弱性（Vulnerability）与对策（Control）之间的逻辑关联。

风险公式的底层逻辑：风险是由“威胁”利用了系统的“脆弱性”而产生的。

威胁与脆弱性的判定逻辑：如果经过风险评估，确认某种“威胁”根本不存在（或者发生概率为零），那么该威胁对应的“脆弱性”也就失去了被利用的土壤，因此去针对它采取对策的必要性就很低（脅威が存在しないと判断できる場合、脆弱性に対処する必要性は低い）。

为什么“**脅威が存在しないと判断できる場合、脆弱性に対処する必要性は低い。**”是正确答案？

- **深度拆解：**这精准契合了信息安全风险管理（Risk Management）的经济学与实用性原则。风险是“威胁”与“脆弱性”乘积的体现。如果压根没有外在的威胁（比如把服务器彻底物理拔网线、锁在绝对隔离的深山里，网络黑客攻击的威胁为零），那么即使系统本身存在某些理论上的脆弱性，由于没有威胁去利用它，我们也没有必要大费周章去专门针对它做修复或对策。

“风险管理考点速记” 口诀：

- 看到 **脅威と脆弱性** → 脑子里瞬间锁定：「**脅威がないなら、対策の必要性も低い**」（没有威胁，应对的必要性就低）。

93. 本题考查的是信息安全基础概念中，用来描述系统或软件中存在的“安全漏洞/缺陷”的专业术语。

什么是“弱点与缺陷”（Security Hole / 脆弱性）？ 在计算机科学中，系统设计、代码编写或配置过程中不可避免地会留下一些疏忽和破绽。这些被黑客或不正当访问利用来搞破坏的系统弱点，在行业术语中通常被称为**セキュリティホール (Security Hole / 安全漏洞 / 漏洞)**。

为什么“**セキュリティホール (Security Hole)**”是正确答案？

- **深度拆解：**这精准命中了题干中所描述的“弱点や欠陥 (弱点与缺陷)”的定义。Security Hole（安全漏洞）就是专门指代系统中那些能够被攻击者利用、导致安全防线出现“洞口”的缺陷。

为什么其他选项是错误项？

- インシデント (Incident): 这是指已经发生的信息安全“事件/事故”（例如数据泄露了、系统被黑了），而不是漏洞本身。
- ハッキング (Hacking): 这是指黑客入侵或攻击的“行为/技术”，不是系统自身的弱点。
- フォレンジック (Forensics): 这是指数字取证（电脑取证），即在事故发生后对现场进行调查取证的技术，与系统漏洞无关。

“安全漏洞考点速记” 口诀：

- 看到 弱点や欠陥 (弱点与缺陷) → 脑子里瞬间锁定黄金词：「セキュリティホール」 (Security Hole)。

94. 本题考查的是密码学中单向散列函数 (Hash Function) 的核心安全性质之一——衝突発見困難性 (Collision Resistance / 抗碰撞性 / 冲突发现困难性)。

- 什么是冲突 (Collision)？不同的两个明文消息 ($M_1 \neq M_2$)，经过哈希函数计算后，如果得到了完全相同的哈希值 ($H(M_1) = H(M_2)$)，这就叫做“发生冲突”。
- 什么是冲突发现困难性 (抗碰撞性)？它是指在计算上极其难以找到任意两个不同的消息，使它们的哈希值相同。其衡量标准是：寻找两个能产生相同哈希值的不同消息 (二つのメッセージ) 所需的计算量巨大度。

为什么“ハッシュ値が一致する二つのメッセージの探索に要する計算量の大きさによる, 探索の困難性のことである。”是正确答案？

- 深度拆解：这精准命中了密码学中“冲突发现困难性 (抗碰撞性)”的学术定义。它特指：找出两个能让哈希值完全一致的不同消息 (二つのメッセージ) 在计算上是极其困难的。这正是“冲突发现 (Collision Finding)”的含义。

“抗碰撞性考点速记” 口诀：

- 看到 衝突発見困難性 → 脑子里瞬间锁定黄金词：「二つのメッセージ」 (两个不同的消息) + 「一致する」 (哈希值一致)。

95. 本题考查的是计算机病毒演化形态中经典的逃逸技术——ポリモーフィック型ウイルス (Polymorphic Virus / 多态性病毒)。

什么是多态性病毒 (Polymorphic Virus)？传统的杀毒软件主要依靠病毒的“特征码 (固定的代码签名)”来识别病毒。而多态性病毒为了躲避杀毒软件的追杀，设计了一种机制：每感染一个新文件，或者每次自我复制时，都会用完全不同的随机密钥对自身的病毒主体进行重新加密 (感染するごとにウイルスのコードを異なる鍵で暗号化する)。

它的最终效果是什么？尽管它的解密后代码干的是同一件坏事，但由于外层的加密壳每次都在变，导致它的外表代码完全不重复，从而让杀毒软件无法通过单一的固定模式 (同一のパターン) 把它检测出来。

“多态性病毒考点速记” 口诀：

- 看到 ポリモーフィック型ウイルス → 脑子里瞬间锁定黄金词：「異なる鍵で暗号化」 (用不同的密钥加密) + 「同一のパターンで検知されない」 (不被相同的模式检测到)。

96. 本题考查的是密码学中安全散列函数（Secure Hash Function，如 SHA 系列）的核心特性——**输出长度的固定性**。

什么是 SHA-256？ 它的全称中“-256”就明确规定了它的输出结果。无论你输入进去的消息（Message）长度是多长（无论是 32 比特、256 比特，还是像一整本书那样长达 2,048 比特），只要经过 SHA-256 算法处理，最终吐出来的**哈希值（Hash Value / ハッシュ値）**的长度永远是固定不变的 256 比特。

“SHA 算法考点速记” 口诀：

- 看到 **SHA-256** 问哈希值长度 → 脑子里瞬间锁定数字：「永远是 256」。

97. 本题考查的是信息安全与身份认证技术中的基础概念——**バイオメトリクス認証 (Biometric Authentication / 生物特征认证)**。

核心考点解析：

- 什么是生物特征认证？它是利用人类身体上独一无二的生理特征（如指纹、掌纹、虹膜、面部）或行为特征（如签名笔迹、步态）来进行身份鉴别的技术。
- 它的核心特征是什么？必须是“身体自带的、无法轻易复制的生物特征”。例如，将手掌放在扫描仪上通过掌纹或静脉识别（**手のひらを読み取り機にかざすことによる認証**），就属于典型的生物特征认证。

98. 本题考查的是 Web 应用安全中最基础、最高频的漏洞与攻击手法——**SQLインジェクション攻撃 (SQL Injection / SQL注入攻击)**。

什么是 SQL 注入？ 当 Web 应用程序在处理用户输入（如登录框、查询框的文本）时，如果没有对输入内容进行严格的过滤或参数化处理，直接拼接到数据库的查询语句中。

它的攻击原理是什么？ 攻击者故意在输入框中输入精心构造的 SQL 语句片段（恶意的查询或操作命令，例如 `' OR '1'='1`），从而欺骗数据库执行非授权的指令，达到非法窃取、篡改或删除数据库中核心数据（データベースのデータを不正に取得したり改ざんしたりする）的目的。

为什么“Webアプリケーションに問題があるとき、悪意のある問合せや操作を行う命令文を入力して、データベースのデータを不正に取得したり改ざんしたりする攻撃”是正确答案？

- 深度拆解：**这精准命中了 SQL 注入攻击的字面含义与技术本质。它明确指出了两点：第一，输入了带有恶意的查询或操作命令（悪意のある問合せや命令文）；第二，最终目的是针对数据库（データベース）进行非法获取或篡改（不正に取得したり改ざんしたりする）。完美契合！

“SQL 注入考点速记” 口诀：

- 看到 **SQLインジェクション** → 脑子里瞬间锁定黄金词：「データベース」（数据库）+ 「不正に取得したり改ざんしたり」（非法获取或篡改）。

99. 本题考查的是信息安全中消息认证码（MAC: Message Authentication Code）的核心机制与密钥分配原则。

什么是消息认证码（MAC）？ 它是一种用来确认消息完整性并验证发送者身份的技术。

MAC 使用什么密钥？ 消息认证码（MAC）的核心机制是基于**共通鍵密码方式（对称密钥密码方式）**。这意味着，发送者在生成 MAC 时使用的密钥，与接收者在验证 MAC 时使用的密钥必须是**完全相同的同一把共享密钥（受信者と共有している共通鍵）**。只有双方拥有这把相同的密钥，才能算对上暗号。

“MAC 密钥考点速记” 口诀：

- 看到 **メッセージ認証符号 (MAC)** → 脑子里瞬间锁定黄金词：**「共通鍵」**（共通密钥）。

消息认证码 (MAC) 就像是一个双胞胎密码箱。

哥哥（发送者）用这把钥匙把箱子锁上并贴上封条；弟弟（接收者）手里也必须有同一把一模一样的钥匙（共通鍵）才能打开并验证封条。

如果两个人用的钥匙不一样，或者用的是什么公开的钥匙，那就变成数字签名了。只要是 MAC，双方就必须用**同一把共享钥匙！**

100. 本题考查的是信息安全管理与内部控制中著名的管理学理论——**不正のトライアングル (Fraud Triangle / 舞弊三角理论)**。该理论由美国学者提出，用来解释内部人员为什么会进行违法违规或舞弊行为。

核心考点解析：

■ **舞弊三角理论的三大要素：**

- 動機 (Pressure / 压力与动机)：**促使员工实施舞弊的外部压力或内部个人需求（如财务困难、业绩压力）。
- 機会 (Opportunity / 机会)：**由于内部控制松懈、系统缺乏监督、物理环境或规章制度漏洞，导致员工觉得“有机可乘、容易得手且不易被发现”。
- 正当化 (Rationalization / 正当化/合理化)：**员工为了克服内心的道德负罪感，自我安慰的借口（如“公司对不起我，这是我应得的”、“我只是借用一下以后会还”）。

为什么“机会 (機会)” 的选项是正确答案？

- 深度拆解：**这精准匹配了舞弊三角中“機会 (Opportunity)”的定义。它明确指出：机会是指信息系统等技术、物理环境以及组织规则等，能够让内部人员进行违规行为变得可能或容易的环境（内部者による不正行為の実行を可能, 又は容易にする環境の存在である）。完美契合！

“舞弊三角考点速记” 口诀：

- 看到 **不正のトライアングル** 考机会 → 脑子里瞬间锁定黄金词：**「可能、容易にする環境」**（让违规变得可能或容易的环境）。

101. 本题考查的是 Web 安全中一种经典的视觉欺骗与诱导点击攻击——**クリックジャッキング (Clickjacking / 点击劫持)**。

核心考点解析：

- **什么是点击劫持（Clickjacking）？** 攻击者利用透明的层（Transparent Layer）或层叠样式表（CSS），将一个带有恶意操作的目标网站（如转账按钮、关注按钮）隐藏或覆盖在一个看似无害的诱饵网站（如抽奖、好看的照片）上面。
- **它的核心运作方式是什么？** 用户以为自己在点击诱饵网站的某个按钮，但实际上他们的鼠标点中的却是被透明化覆盖在下方的另一个恶意/受害网站上的核心操作按钮（WebサイトAのコンテンツ上に透明化した標的サイトBのコンテンツを配置し、WebサイトA上の操作に見せかけて標的サイトB上で操作させる），从而在不知情中被“劫持”并执行了危险操作。

“隐形透明玻璃板与恶作剧按钮的比喻”：

- **クリックジャッキング** 就像是一个恶作剧：坏人在一个很好看的动漫网页 A（WebサイトA）上面，盖了一块完全透明的隐形玻璃板（透明化したコンテンツ）。
- 玻璃板底下其实压着另一个危险的银行转账网页 B（標的サイトB）。
- 你高高兴兴地以为自己在点动漫网页上的“领取奖品”按钮，结果手点下去的一瞬间，力气穿透了透明玻璃，把底下银行网页的“确认转账”给点烂了！这种“移花接木、借刀杀人”的点鼠标恶作剧，就是点击劫持！

“点击劫持考点速记” 口诀：

- 看到 **クリックジャッキング** → 脑子里瞬间锁定黄金词：「透明化」（透明化）+ 「見せかけて操作させる」（伪装成A网站的操作去操作B网站）。

102. 本题考查的是信息安全与密码学中时间戳（Timestamp）的核心法律效力与应用目的。

◦ **核心考点解析：**

- **什么是时间戳（Timestamp）？** 由权威的“时间戳机构（TSA）”对电子文档加上一个不可篡改的精确时间标记。
- **它的两大核心法律效果是什么？**
 1. **存在性证明（存在証明）：** 证明该电子文档在时间戳标记的那个时间点或之前就已经真实存在了。
 2. **防止否认（非否認 / 否認防止）：** 因为证明了“文件在某个时间点就已经存在且属于我”，所以文件的创作者事后无法耍赖、无法否认自己曾在这个时间点创作过该文件（電子文書が、タイムスタンプの時刻以前に存在したことを示すことによって、作成者が電子文書の作成を否認することを防止する）。

为什么“電子文書が、タイムスタンプの時刻以前に存在したことを示すことによって、作成者が電子文書の作成を否認することを防止する。”是正确答案？

- **深度拆解：** 这精准命中了时间戳的核心法律功能。通过时间戳盖章，能够向外界确凿地证明：“这份电子文件在XX年XX月XX日这个时间点就已经存在了”。这就直接堵住了作者想事后不认账、抵赖说“这不是我做的”或者“这不是那时候做”的退路（防止创建者否认 / 否認の防止）。完美契合！

“时间戳考点速记” 口诀：

- 看到 **タイムスタンプ (时间戳)** → 脑子里瞬间锁定黄金词：「**以前に存在したことを示す**」(证明以前存在) + 「**否認を防止**」(防止否认/赖账)。

103. 本题考查的是多因素认证 (Multi-Factor Authentication) 中不同认证方式的组合逻辑、安全性强度以及系统设计上的安全与便利性平衡。

- **核心考点解析：**

- **认真分析题目中的认证步骤 (认证手順)：**

1. 虹彩認証成功 $\rightarrow$ 直接登录 (说明虹彩認証是**第一道防线**)。
2. 虹彩認証失敗3次 $\rightarrow$ 要求输入密码 (说明系统给了备用通道)。
3. 密码正确 $\rightarrow$ 登录成功；密码失敗3次 $\rightarrow$ 账户锁定。

- **安全性与强度的本质：**在密码学和认证体系中，增加生物特征认证 (如虹彩/眼纹) 并将其作为主要或前置认证，利用了人体生物特征的独一无二性，因此**与单纯的密码认证相比，整体认证的强度更高 (パスワード認証だけに比べて認証の強度が高い)**。

- **为什么“选项 ウ” 是正确答案？**

- **深度拆解：**这精准命中了信息安全认证的常识。虹彩属于人体固有的生理生物特征 (本人固有**の生体情報**)，将其加入到认证系统中 (哪怕是作为组合或前置步骤)，相比于单纯只靠容易被猜中或泄露的密码认证，其整体的身份鉴别安全强度 (認証の強度) 得到了显著提升。

- **为什么其他选项是错误项？**

- **选项 ア：**并用了生物认证并不意味着密码就可以不定期更换，密码安全策略依然需要。
- **选项 イ：**虽然虹彩失败后可以输密码，但题目逻辑中虹彩不通过还要走密码，且如果虹彩由于体感失败通常应重新扫描，题目步骤②③实际上是一种**降级回退 (Fallback) 或复合验证**机制，但它本身并不是为了“提高便利性”而设计的，反而因为流程变多可能降低了便利性。
- **选项 エ：**注意看题目步骤②，虹彩失败3次才让输入密码，如果虹彩本身把“他人误认为本人 (Type-2 Error / 他人接受率 FAR)” ，那么就登录了 (步骤①)，根本不会走到输入密码的步骤。因此选项エ说“虹彩误认后还能用密码检查”是不符合步骤逻辑的。

“生物特征认证考点速记” 口诀：

- 看到 **生体認証 (生物特征认证)** 参与的组合系统 → 脑子里瞬间锁定黄金词：「**強度が高い**」(强度更高)。

104. 本题考查的是现代对称密钥密码标准——**AES (Advanced Encryption Standard / 高级加密标准)** 的核心结构与运作机制。

- **核心考点解析：**

- **什么是 AES？** 它取代了老旧的 DES，是目前广泛应用于无线网 (如 WPA2/WPA3)、SSL/TLS 和文件加密的高强度共通鍵暗号 (对称密钥密码) 算法。

- **它的核心特征是什么？** AES 支持 128、192、256 比特三种不同的密钥长度（鍵長）。在其算法内部，重复执行转换步骤的**轮数/段数（ラウンド数 / 段数）并不是人为随意决定的，而是严格由你所选择的“密钥长度（鍵長）”来自动决定的**（例如：128位密钥对应10轮，192位对应12轮，256位对应14轮）。

○ **为什么“键长决定段数（鍵長によって、段数が決まる。）”是正确答案？**

- **深度拆解：**这精准命中了 AES 算法的规范定义。AES 的加密结构（基于 Rijndael 算法）规定：密钥越长，内部需要重复循环的混合加密“段数/轮数（ラウンド）”就越多。因此，“段数由密钥长度决定”是绝对正确的科学事实。

“造房子时钢筋粗细决定层数的比喻”：

- **AES** 就像是一座标准的现代化高强度密码大楼。
- 你选择用多粗的密码钥匙（鍵長），大楼自动就要用对应层数的工序去打造（**段数が決まる**）。钥匙粗细和内部盖几层楼（段数）是死死绑定的，不能由工人随便在 6 次以内瞎选。
- 至于什么“加密-解密-加密重复3次”，那是老掉牙的 3DES 老古董才干的事。所以一眼就能选出正确的 AES 特征！

“AES 考点速记” 口诀：

- 看到 **AES** 问特征 → 脑子里瞬间锁定黄金词：**「鍵長によって段数が決まる」**（由密钥长度决定段数）。

105. 本题考查的是 **公開鍵暗号（公开密钥密码/非对称密码）** 在多人相互通信时，整个系统所需的密钥总数计算方式。

○ **核心考点解析：**

- 在公开密钥体系中，密钥是**按人头**独立生成的。
- **每个人**都需要拥有一套专属的密钥对，即 **1 个公开密钥（公開鍵）** 和 **1 个秘密密钥（秘密鍵）**。
- 题目中明确规定：“一組の公開鍵と秘密鍵は2個と数える（一组公钥和私钥算 2 个）”。也就是说，**每个人自己身上就有 2 个密钥**

为什么“2n”是正确答案？

○ **深度拆解：**

- 假设系统里有 n 个人需要相互通信。
- 每一个参与者都需要生成属于他自己的一套公私钥对。
- 根据题目条件，每人有 1 套，也就是 **2 个密钥**。
- 那么 n 个人总共需要的密钥总数，就是人数 n 乘以每人拥有的 2 个密钥，即 $n \times 2 = 2n$ 。

为什么其他选项是错误项？

- 选项 ア ($n + 1$): 完全没有数学依据的错误干扰项。
- 选项 ウ ($\frac{n(n-1)}{2}$): 这是 **共通鍵暗号 (对称密钥密码)** 在两两通信时所需的共享密钥总数 (因为对称密码需要两两之间单独建一条线共享钥匙)。考试最喜欢用它来混淆视听!
- 选项 エ ($\log_2 n$): 与本题无关的对数运算。

“公开密钥数量计算考点速记” 口诀:

- 看到 **公開鍵 + n人が相互に通信** → 脑子里瞬间锁定: 「直接乘2, 选 $2n$ 」。

106. 本题考查的是 SSL/TLS 安全通信建立过程中, 客户端 (PC) 如何利用数字证书与认证局 (CA) 的公钥来验证服务器身份的核心机制。

◦ **核心考点解析:**

- **数字证书的本质:** Web 服务器的数字证书是由认证机构 (CA) 用自己的秘密密钥 (私钥) 进行数字签名 (加密盖章) 生成的。
- **客户端的验证流程:** 当 PC 拿到服务器的数字证书后, 为了确认这个证书是不是真的由官方 CA 签发的、中途有没有被假冒, PC 必须使用**认证机构的公开密钥 (認証局の公開鍵)** 去对证书上的数字签名进行解密和验证 (**デジタル証明書の正当性を検証する**)。

为什么“数字证书的正当性用认证局的公钥进行验证 (**デジタル証明書の正当性を認証局の公開鍵を使って検証する。**)” 是正确答案?

- **深度拆解:** 这精准命中了 PKI (公钥基础设施) 中数字签名验证的铁律。CA 用私钥签名, 全世界任何人都可以用 CA 的公钥来验证。PC 拿到 A 公司的服务器证书后, 第一件事就是用系统内置的 CA 公钥去验明正身, 看看证书是不是原装正品、有没有被篡改。完美契合!

为什么其他选项是错误项?

- 选项 ア & イ: 在 SSL/TLS 握手时, 客户端生成用于后续加密通信的共通鍵 (对称密钥) 后, 通常是用**服务器的公开密钥**去加密它, 而不是用“认证局的公钥”去加解密。
- 选项 エ: 用户输入的秘匿数据 (如密码) 是用**服务器的公开密钥**进行加密传输的, 不是用认证局的公钥。

“认证局公钥考点速记” 口诀:

- 看到 **認証局の公開鍵** → 脑子里瞬间锁定黄金词: 「**デジタル証明書の正当性を検証**」 (验证数字证书的正当性/真伪)。

107. 本题考查的是网络安全与常见网络端口 (Port) 的基础知识——**TCP 23番ポート (Telnet 协议及其在 IoT 设备中的安全隐患)**。

◦ **核心考点解析:**

- **什么是 TCP 23番ポート?** 它是远端明文终端管理协议 **Telnet** 的标准通信端口。

- **为什么 IoT 设备的 23 号端口攻击最多？** 许多网络摄像头、路由器等 IoT 设备的出厂默认设置开启了 Telnet 服务（即 23 号端口），且往往使用出厂自带的极其简单的**初始密码（初期パスワード）**。黑客利用这一弱点，通过 23 端口轻易进行暴力破解或直接登录，从而劫持 IoT 设备（初期パスワードを使って不正ログインが容易に成功し、不正にIoT機器を操作できる）。

为什么“TCP23番ポートはIoT機器の操作用プロトコルで使用されており、そのプロトコルを用いると、初期パスワードを使って不正ログインが容易に成功し、不正にIoT機器を操作できることが多いから”是正确答案？

- **深度拆解：**这精准命中了 23 号端口（Telnet）的漏洞本质。23 号端口对应的正是设备操作协议 Telnet，而无数 IoT 灾难的根源就在于设备出厂带有默认弱密码（初始密码），导致黑客能轻而易举地通过该端口登录并接管设备。完美契合！

“23番ポート 考点速记” 口诀：

- 看到 TCP 23番ポート 或 IoT → 脑子里瞬间锁定黄金词：「**初期パスワード**」（初始密码）+ 「**不正ログイン**」（不正当登录/远程操作）。

108. 本题考查的是现代密码学（特别是公开密钥加密方式 / 公開鍵暗号方式）中著名的柯克霍夫原则（Kerckhoffs's principle）与非对称密码体制的基本安全属性。

○ **核心考点解析：**

- **什么是公开密钥加密？** 在这种体制中，有一对密钥：一个是用来加密的**暗号化鍵（即公开密钥 / 公開鍵）**，它是公开给全世界的；另一个是用来解密的**復号鍵（即秘密密钥 / 秘密鍵）**，它必须由接收者严格保密（秘密にしなければならない）。
- **加密算法需要保密吗？** 根据现代密码学的基石——柯克霍夫原则，密码系统的安全性不依赖于加密算法本身的机密性，而完全依赖于“密钥（特别是私钥）”的保密。因此，**暗号化アルゴリズム（加密算法）是公开的，不需要隐瞒。**
- 为什么“暗号化鍵と暗号化アルゴリズムは公開するが、復号鍵は秘密にしなければならない。”是正确答案？
 - **深度拆解：**这精准命中了公开密钥密码的运作真谛。
 1. **暗号化鍵 (加密密钥/公钥)** 是用来发信的，必须公开（公開する）让大家都能给你写信。
 2. **暗号化アルゴリズム (加密算法)** 在现代密码学中也是公开的（公开标准算法，如 RSA、ECC），靠算法公开接受全球密码学家的检验来证明其安全性。
 3. 只有用来解密的 **復号鍵 (解密密钥/私钥)** 是万万不能泄露的，必须严格保密（秘密にしなければならない）。完美契合第三个选项！

“公钥密码保密性考点速记” 口诀：

- 看到 公開鍵暗号 问什么该公开、什么该保密 → 脑子里瞬间锁定：「**公钥和算法公开，私钥（复号键）必须保密**」。

109. 本题考查的是数据库管理中的 **SQL 权限管理 (GRANT)** 与信息安全管理中的**完全性 (Integrity / 完整性)**。

◦ **核心概念辨析 (INSERT 与 SELECT 的区别)：**

- **SELECT (查询)：**就像是“拿出一张纸看上面的内容”。它只负责读取数据，不会改变数据的内容。
- **INSERT (插入/写入)：**就像是“在账本上写新的一行”。它会改变、增加数据，直接关系到数据的**完全性 (Integrity)**。

◦ **本题的考核逻辑：**根据 JIS Q 27001 的安全管理要求，如果组织规定某个用户“绝对不应该访问”某个表格，或者对某个表格只有“只读权限”，那么赋予他超出权限的操作（特别是修改、写入或非授权访问）就会破坏数据的安全与完整性。

◦ **为什么“GRANT SELECT ON X TO B”是正确答案？**

■ **深度拆解：**

1. 题目表格 X (注文テーブル / 订单表) 的访问要件 (アクセス要件) 写得清清楚楚：“② 管理课的使用者 B 不访问 (管理課の利用者Bはアクセスしない)”。
2. 这意味着 B 连看一眼 X 表的资格都没有。
3. 选项 **工** 中的 `GRANT SELECT ON X TO B` 意思是：**把对 X 表的“查询(SELECT)”权限授予了本来根本不该访问该表的 B**。这直接违反了访问控制规则，构成了违规授权，从而威胁了系统安全性。

◦ **为什么其他选项是错误项 (或非本题要害)？**

- **选项 ア (GRANT INSERT ON Y TO A)：**Y 表的要件是 A 只能“照会 (查询)”，虽然给 A 赋 INSERT 权限不符合要件，但对照历年真题的标准答案，直接违背“绝对不能访问 (アクセスしない)”这一禁令的选项 **工** 更加典型和严重。
- **选项 イ & ウ：**分别对应其他不符合题意的权限组合。

“访问控制考点速记” 口诀：

◦ 看到 **アクセスしない** (不访问) → 脑子里瞬间锁定：「不能给这个人发任何门禁钥匙」。

110. 本题考查的是信息安全与身份认证技术中 **バイオメトリクス認証 (Biometric Authentication / 生物特征认证)** 的核心评估指标与调优考量。

◦ **核心考点解析：**

■ **生物特征认证的两大错误率指标：**

1. **本人拒否率 (FRR - False Rejection Rate / 错误拒绝率)：**把真实的本人误认为是外人而拒绝掉的概率。
2. **他人受容率 (FAR - False Acceptance Rate / 错误接受率)：**把外人误认为是本人而放行通过的概率。

- **系统引入与调优的难点**：这两者是此消彼长的关系（把门槛调严了，FAR降低但FRR升高；把门槛调松了，FRR降低但FAR升高）。因此，在引入和调整设备时，**必须同时兼顾并平衡这两项指标（本人の誤って拒否する確率と他人の誤って許可する確率の双方を勘案して装置を調整する）**。

为什么“本人の誤って拒否する確率と他人の誤って許可する確率の双方を勘案して装置を調整する。”是正确答案？

- **深度拆解**：这精准命中了生物特征认证系统设计与调优的核心原则。生物识别不是非黑即白的，它永远存在误判。引入时必须综合考虑“拒绝真主人的概率（FRR）”与“放走假坏人的概率（FAR）”双方（双方を勘案して），并以此来校准设备的敏感度。完美契合！

“生物特征认证考点速记” 口诀：

- 看到 **生体認証** 考引入或调整时考虑的事项 → 脑子里瞬间锁定：**「双方を勘案する」**（双方共同考量/权衡）。